

République Tunisienne

Ministère de l'Enseignement Supérieur

et de la Recherche Scientifique

École Supérieur Privée d'ingénierie et de technologie

TEK-UP



Rapport de Projet de Fin d'Année

Présenté en vue de l'obtention du

Diplôme National d'Ingénieur en Sciences Appliquées et Technologiques

Spécialité : Génie Informatique – Cybersécurité

Réalisé par

Thamer Bousbia

Mise en place d'une solution SOC open source pour la détection et la gestion des incidents de sécurité

Encadrant professionnel : **M. Mohamed Helmi Messaoudi**

Remerciements

J'adresse mes sincères remerciements à mon encadrant professionnel, M. Mohamed Helmi Messaoudi, pour son accompagnement technique, sa disponibilité, la qualité de ses conseils et la confiance accordée tout au long de ce projet réalisé au sein de la Société Tunisienne de Banque.

Je remercie la Société Tunisienne de Banque pour son accueil et pour l'opportunité de travailler sur une problématique concrète de cybersécurité dans le secteur bancaire. Je remercie également l'ensemble du corps enseignant de TEK-UP pour les connaissances scientifiques et pratiques transmises durant ma formation, ainsi que mes collègues, mes proches et toutes les personnes ayant participé aux échanges, aux essais et à la relecture de ce travail.

Enfin, je remercie les communautés qui développent et maintiennent pfSense, Wazuh, TheHive, Cortex, MISP, DVWA et les référentiels ouverts de cybersécurité. Leur travail rend possible la construction d'environnements pédagogiques réalistes, reproductibles et accessibles.

Table des matières

Liste des acronymes **ix**

Introduction générale **1**

1 Contexte de la STB et fondements d'un SOC **4**

1.1 Présentation de la Société Tunisienne de Banque 5

1.2 Cybersécurité 5

1.2.1 Confidentialité 6

1.2.2 Intégrité 6

1.2.3 Disponibilité 6

1.3 Centre des opérations de sécurité 7

1.3.1 Missions et organisation 7

1.3.2 Architecture fonctionnelle 7

1.4 SIEM 7

1.4.1 Collecte et normalisation 7

1.4.2 Corrélation et détection 8

1.5 SOAR 8

1.6 Threat Intelligence 8

1.7 OWASP Top 10 8

2 Analyse et conception du laboratoire SOC **10**

2.1 Cahier des charges 11

2.2 Analyse des besoins 11

2.2.1 Besoins fonctionnels 11

2.2.2 Besoins non fonctionnels 11

2.3 Choix des outils 12

2.4 Architecture générale 12

2.4.1 Description des flux 13

2.5 Diagramme du flux de données 13

2.6 Plan d'adressage IP 13

2.7 Risques de conception et contrôles 14

3 Mise en œuvre du laboratoire **15**

3.1 Installation de VMware Workstation 16

3.2 Configuration de pfSense 17

3.3 Déploiement de Wazuh 19

3.3.1 Sources collectées 19

3.4 Installation de Windows Server 2019 20

3.5 Installation d'Ubuntu Server et de DVWA 21

3.6 Installation de Kali Linux 22

3.7 Déploiement de TheHive 23

3.8 Déploiement de Cortex 23

3.9 Déploiement de MISP 24

3.10 Intégration des composants 24

3.10.1 Démarche de diagnostic 25

4 Tests et validation **26**

4.1 Scénario 1 : attaque SSH par force brute 27

4.2 Scénario 2 : attaque RDP par force brute 27

4.3 Scénario 3 : altération de fichiers avec FIM 28

4.4 Scénario 4 : scan réseau et vulnérabilités 29

4.5 Scénario 5 : reconnaissance contre pfSense 30

4.6 Scénario 6 : OWASP Top 10 sur DVWA 31

4.6.1 Méthode commune 31

4.6.2 A01 – Broken Access Control 32

4.6.3 A02 – Cryptographic Failures 32

4.6.4 A03 – Injection 32

4.6.5 A04 – Insecure Design 32

4.6.6 A05 – Security Misconfiguration 32

4.6.7 A06 – Vulnerable and Outdated Components 33

4.6.8 A07 – Identification and Authentication Failures 33

4.6.9 A08 – Software and Data Integrity Failures 33

4.6.10 A09 – Security Logging and Monitoring Failures 33

4.6.11 A10 – Server-Side Request Forgery 34

4.7 Active Response 36

4.8 Tableau MITRE ATT&CK 38

4.9 Discussion des résultats 38

Conclusion générale **40**

Bibliographie **41**

Annexes **42**

Annexe A – Décodeur et règles pfSense 42

Annexe B – Règle FIM sélective 42

Annexe C – Extrait des règles OWASP 42

Annexe D – Commandes de validation 43

Annexe E – Précautions de sécurité 43

Table des figures

1.1 Organigramme de référence de la Société Tunisienne de Banque, document daté du 10 juin 2020 6

2.1 Architecture complète du laboratoire SOC fournie avec le projet 13
2.2 Reproduction synthétique du flux de détection et de réponse 13

3.1 Configuration du réseau Host-only VMnet1 dans VMware Workstation 16
3.2 Interfaces WAN/LAN et tableau de bord de pfSense 17
3.3 Règles de filtrage et configuration NAT de pfSense 18
3.4 Configuration du transfert syslog de pfSense vers Wazuh 18
3.5 Vue générale du Dashboard Wazuh et état des agents 19
3.6 Enrôlement de l'agent Ubuntu Server dans Wazuh 20
3.7 Installation d'Active Directory Domain Services 21
3.8 Enrôlement de Windows Server 2019 dans Wazuh 21
3.9 Déploiement du conteneur Docker DVWA sur Ubuntu Server 22
3.10 Interface DVWA et configuration du niveau de sécurité 22
3.11 Interface TheHive et vue des alertes sur le port 9000 23
3.12 Interface Cortex et liste des analyseurs disponibles 24
3.13 Événements de renseignement publiés dans MISP 24

4.1 Détection Wazuh de la force brute SSH – règles 5503 et 5760 visibles 27
4.2 Détection Wazuh de la force brute RDP – règle 60122 visible 28
4.3 Alertes File Integrity Monitoring – règles 550 et 554 visibles 29
4.4 Résultats du module Wazuh Vulnerability Detection 30
4.5 Scan Nmap contre pfSense depuis Kali Linux 30
4.6 Journaux filterlog générés par pfSense après le scan 31
4.7 Alertes pfSense reçues dans Wazuh – règles 100160 et 100161 visibles 31
4.8 Détection des attaques OWASP A01 à A05 dans Wazuh 33
4.9 Détection des attaques OWASP A06 à A10 dans Wazuh 34
4.10 Alertes Wazuh visibles dans TheHive 35
4.11 Analyse d'un observable avec Cortex et VirusTotal 35
4.12 Analyse de réputation d'une adresse IP avec AbuseIPDB 36

4.13 Traçabilité de la publication de l'événement MISP 36
4.14 Configuration de la réponse active firewall-drop dans Wazuh 37
4.15 Exécution de la réponse active – règle 651 « Host Blocked by firewall-drop » 38

Liste des tableaux

1.1 Catégories de l'OWASP Top 10 :2021 9

2.2 Rôle des composants du laboratoire 12
2.4 Plan d'adressage du réseau privé 192.168.100.0/24 14

3.1 Validation des intégrations du laboratoire 25

4.1 Occurrences de vulnérabilités rapportées par Wazuh 29
4.2 Synthèse des règles Wazuh pour l'OWASP Top 10 35
4.3 Cartographie des scénarios avec MITRE ATT&CK 38

Liste des acronymes

AD	Active Directory
API	Application Programming Interface
CTI	Cyber Threat Intelligence
CVE	Common Vulnerabilities and Exposures
DVWA	Damn Vulnerable Web Application
EDR	Endpoint Detection and Response
FIM	File Integrity Monitoring
HIDS	Host-based Intrusion Detection System
HTTP	Hypertext Transfer Protocol
IDS	Intrusion Detection System
IOC	Indicator of Compromise
LAN	Local Area Network
MISP	Malware Information Sharing Platform
NAT	Network Address Translation
OWASP	Open Worldwide Application Security Project
RDP	Remote Desktop Protocol
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation and Response
SOC	Security Operations Center
SSH	Secure Shell
SSRF	Server-Side Request Forgery
TLS	Transport Layer Security
VM	Virtual Machine
XSS	Cross-Site Scripting

Introduction générale

La transformation numérique a accru la dépendance des organisations aux systèmes d'information, aux services en ligne et aux échanges interconnectés. Cette évolution améliore la productivité, mais étend simultanément la surface d'attaque : postes de travail, serveurs, identités, applications web, équipements réseau et services externalisés produisent un volume d'événements qu'une analyse manuelle ne peut plus absorber. Le risque ne résulte donc pas uniquement de l'existence d'une vulnérabilité ; il dépend aussi de la capacité à observer son exploitation, à distinguer un signal pertinent du bruit et à agir avant que l'incident ne se propage.

Le centre des opérations de sécurité, ou SOC, répond à ce besoin par une combinaison de personnes, de processus et de technologies. Sa mission consiste à superviser les actifs, centraliser les journaux, détecter les comportements anormaux, qualifier les alertes et coordonner la réponse. Les lignes directrices du NIST structurent cette activité autour de l'identification, de la protection, de la détection, de la réponse et du rétablissement [1], [2]. Dans un contexte académique, la construction d'un laboratoire SOC constitue ainsi un exercice intégrateur : elle mobilise le réseau, les systèmes, l'administration de la sécurité, la détection, l'analyse d'incident et la sécurité applicative.

Contexte de l'organisme d'accueil

Ce projet de fin d'année a été réalisé au sein de la Société Tunisienne de Banque (STB). Créée en 1958, la STB est une banque publique et universelle qui a contribué au développement du secteur bancaire tunisien et au financement de l'économie nationale. Sa transformation numérique, la diversification de ses services et la sensibilité des données bancaires renforcent les exigences de disponibilité, de traçabilité et de protection des systèmes d'information [3].

Dans ce contexte, le laboratoire proposé ne reproduit pas le système d'information de production de la banque et n'utilise aucune donnée réelle de clientèle. Il constitue une maquette isolée destinée à étudier des mécanismes transférables à un environnement bancaire : segmentation, centralisation des journaux, corrélation, gestion des incidents, enrichissement des indicateurs et réponse contrôlée. Cette séparation protège le périmètre réel tout en permettant d'expérimenter des scénarios offensifs de manière encadrée.

Problématique

Les plateformes commerciales de supervision offrent des fonctions avancées, mais leur coût, leur opacité et leurs contraintes de licence limitent leur emploi pédagogique. La problématique retenue est

donc la suivante : *comment concevoir, intégrer et valider un laboratoire SOC open source capable de collecter des événements hétérogènes, de détecter des cyberattaques réseau, système et web, de centraliser les incidents et d'enrichir les indicateurs de compromission ?*

Cette question implique plusieurs difficultés : assurer la connectivité et la segmentation des machines virtuelles ; enrôler des agents Linux et Windows ; normaliser des journaux différents ; écrire des règles sans provoquer de faux positifs excessifs ; transmettre uniquement les alertes utiles ; et établir une traçabilité de bout en bout entre l'action offensive, le journal, la règle, l'alerte et la réponse.

Objectifs

L'objectif principal est de mettre en œuvre un laboratoire reproductible sur VMware Workstation, organisé autour du réseau privé `192.168.100.0/24`. Les objectifs spécifiques sont :

- ✓ configurer pfSense comme passerelle, pare-feu, routeur et point de journalisation ;
- ✓ déployer Wazuh comme SIEM central et superviser des hôtes Linux et Windows ;
- ✓ intégrer TheHive, Cortex et MISP pour la gestion, l'enrichissement et le renseignement ;
- ✓ exécuter des scénarios contrôlés depuis Kali Linux ;
- ✓ évaluer les dix catégories OWASP Top 10 sur DVWA [4] ;
- ✓ mettre en place des règles personnalisées, un filtrage sélectif et une réponse active ;
- ✓ cartographier les scénarios avec MITRE ATT&CK [5].

Méthodologie

La démarche suivie est expérimentale et incrémentale. Après l'étude des concepts, les besoins et l'architecture sont définis. Les composants sont ensuite installés séparément, puis intégrés selon une chaîne de confiance progressive. Chaque scénario suit le cycle : préparation, attaque contrôlée, observation du journal, validation avec `wazuh-logtest`, détection dans Wazuh, transfert vers TheHive, enrichissement et interprétation. Les rapports sources montrent deux jalons : au 6 août 2026, le scénario DVWA était encore en stabilisation ; le rapport complémentaire ultérieur documente la finalisation des règles couvrant A01 à A10. Cette chronologie est conservée afin de distinguer les résultats réellement observés des améliorations proposées.

Organisation du mémoire

Le premier chapitre expose les fondements du SOC, du SIEM, du SOAR, de la CTI et de l'OWASP Top 10. Le deuxième formalise le cahier des charges, les choix technologiques et l'architecture.

Le troisième décrit le déploiement et l'intégration. Le quatrième présente les scénarios, les règles, les résultats, la réponse active et la cartographie MITRE ATT&CK. Une conclusion générale synthétise les apports, les limites et les perspectives ; les annexes regroupent les configurations et commandes utiles à la reproductibilité.

Chapitre 1

Contexte de la STB et fondements d'un SOC

Plan du chapitre

1. Présentation de la Société Tunisienne de Banque
2. Principes fondamentaux de la cybersécurité
3. Centre des opérations de sécurité
4. SIEM et corrélation des événements
5. SOAR et automatisation de la réponse
6. Threat Intelligence
7. OWASP Top 10

Introduction

La mise en œuvre d'un SOC exige un vocabulaire commun et une compréhension claire des fonctions couvertes par chaque composant. Ce chapitre présente d'abord la Société Tunisienne de Banque et les principes fondamentaux de la cybersécurité. Il définit ensuite le SOC et ses principales briques technologiques : SIEM, SOAR et renseignement sur les menaces. Enfin, il introduit l'OWASP Top 10, qui servira de référence aux scénarios applicatifs. Cette progression permet de situer le laboratoire et d'éviter de confondre supervision, détection, corrélation, orchestration et renseignement.

1.1 Présentation de la Société Tunisienne de Banque

La Société Tunisienne de Banque est l'organisme d'accueil du projet. Entrée en activité le 26 mars 1958, elle exerce une activité de banque universelle et accompagne différents segments de clientèle. Son rôle historique dans le financement de l'économie tunisienne et le développement continu de services numériques placent la sécurité de l'information parmi les enjeux nécessaires à la continuité et à la confiance [3].

L'organisation de la banque repose sur des structures de gouvernance, des pôles métiers et des fonctions de support, dont les systèmes d'information et le développement digital. La figure 1.1 reproduit l'organigramme présent dans le rapport de référence fourni. Le document étant daté du 10 juin 2020, il est utilisé comme repère institutionnel et non comme garantie de l'organisation exacte en 2026.

Dans un établissement bancaire, la cybersécurité doit notamment protéger les identités, les transactions, les applications, les infrastructures, les postes de travail et les journaux d'audit. Un SOC contribue à cette mission par la surveillance continue et la coordination de la réponse. Le laboratoire développé dans ce PFE reste néanmoins une plateforme pédagogique indépendante du réseau de production de la STB.

1.2 Cybersécurité

La cybersécurité regroupe les mesures organisationnelles et techniques destinées à protéger les systèmes, les réseaux, les applications et les données contre les accès non autorisés, l'altération, l'indisponibilité et l'abus. Elle ne se réduit pas à l'installation d'outils : l'identification des actifs, la gestion des risques, la gouvernance, la formation et l'amélioration continue en sont des dimensions essentielles [1], [6].

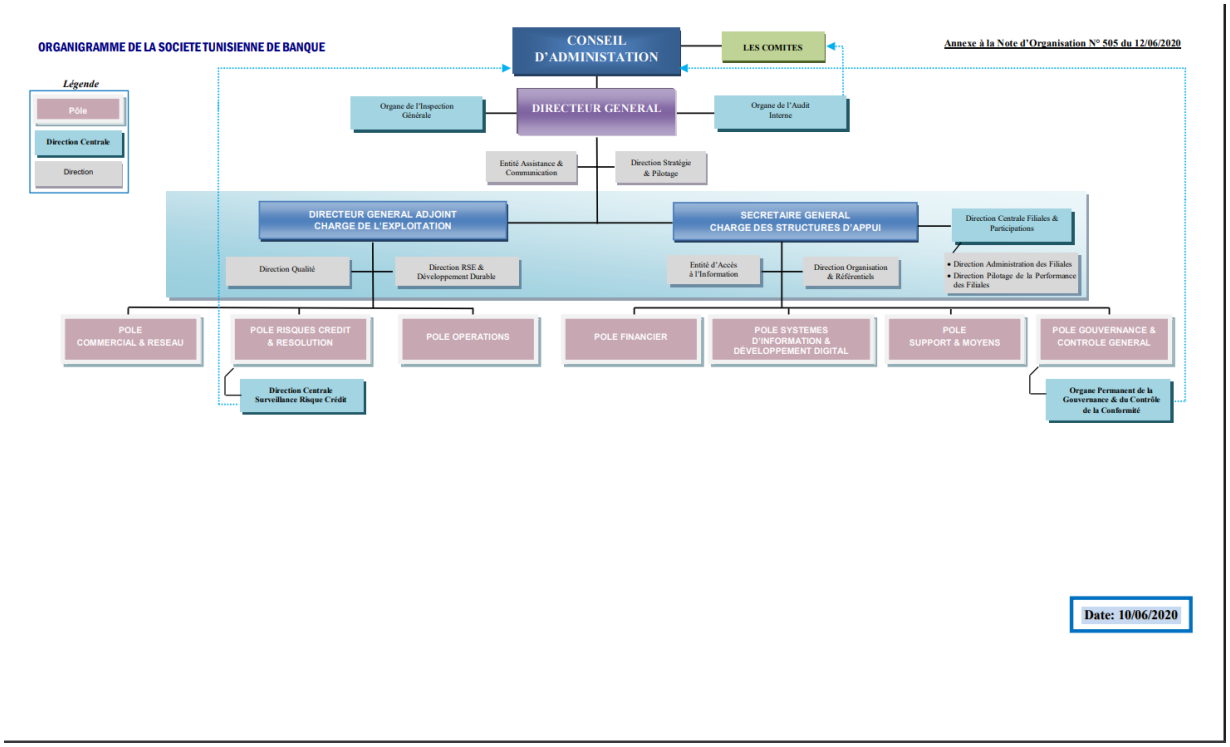


FIGURE 1.1 : Organigramme de référence de la Société Tunisienne de Banque, document daté du 10 juin 2020

1.2.1 Confidentialité

La confidentialité garantit qu'une information n'est accessible qu'aux sujets autorisés. Elle repose notamment sur l'authentification, l'autorisation, le chiffrement, la segmentation et le principe du moindre privilège. Dans le laboratoire, pfSense limite les flux, Active Directory gère les identités Windows et les clés API protègent les échanges entre plateformes.

1.2.2 Intégrité

L'intégrité assure qu'une donnée ou une configuration n'est pas modifiée sans autorisation. Les fonctions de hachage, les signatures, les contrôles de version et la surveillance FIM participent à cet objectif. Wazuh calcule et compare les empreintes des fichiers surveillés afin d'identifier leur création, leur modification ou leur suppression.

1.2.3 Disponibilité

La disponibilité garantit l'accès aux services dans les conditions prévues. Elle dépend de la redondance, de la sauvegarde, de la supervision et de la maîtrise des changements. Dans une maquette virtualisée, l'arrêt d'une VM suffit à interrompre une intégration : l'erreur *No route to host* observée entre Wazuh et TheHive illustre cette dépendance opérationnelle.

1.3 Centre des opérations de sécurité

Un SOC est une capacité organisationnelle qui assure la surveillance continue, la détection, l'analyse et la coordination de la réponse. Son fonctionnement articule trois piliers : les personnes, qui qualifient et investiguent ; les processus, qui définissent l'escalade et la preuve ; et la technologie, qui collecte, corrèle et automatise.

1.3.1 Missions et organisation

Les missions usuelles comprennent l'inventaire des sources, la supervision, la veille, le triage, l'investigation, la réponse et le retour d'expérience. Une organisation en niveaux peut confier au niveau 1 la qualification initiale, au niveau 2 l'investigation approfondie et au niveau 3 la chasse aux menaces et l'ingénierie de détection. Dans le laboratoire, ces rôles sont simulés par un même opérateur, mais les étapes restent séparées pour préserver la traçabilité.

1.3.2 Architecture fonctionnelle

Une architecture SOC reçoit des événements provenant des hôtes, des applications, des identités et des équipements réseau. Le SIEM normalise et corrèle ces données ; la plateforme de gestion d'incident crée un dossier ; les services d'enrichissement ajoutent un contexte ; enfin, une décision humaine ou automatisée déclenche le confinement. La qualité du résultat dépend de la couverture des sources et de la fidélité des horodatages.

1.4 SIEM

Un SIEM centralise les journaux de sécurité, les transforme en événements exploitables et applique des règles de détection. La journalisation normalisée est un prérequis : le protocole syslog est notamment décrit par la RFC 5424 [7]. Wazuh complète cette fonction par des agents, un HIDS, la surveillance d'intégrité et la détection de vulnérabilités [8].

1.4.1 Collecte et normalisation

Les agents Wazuh collectent les journaux Windows, Linux et Apache, tandis que pfSense transmet ses événements en syslog. Les décodeurs extraient ensuite des champs tels que l'adresse source, l'utilisateur, l'URL ou l'identifiant d'événement. Une erreur de décodage rend la meilleure règle inefficace ; le conflit observé entre le message pfSense et un décodeur générique montre l'importance de tester chaque échantillon.

1.4.2 Corrélation et détection

Une règle simple reconnaît un motif dans un événement. Une règle corrélée tient compte de la fréquence, d'une fenêtre temporelle et, si nécessaire, d'une même adresse source. Ainsi, cinq tentatives d'authentification web en soixante secondes sont plus significatives qu'un seul échec. Les niveaux Wazuh, compris entre 0 et 15, permettent de filtrer la transmission vers TheHive.

1.5 SOAR

Le SOAR associe orchestration, automatisation et gestion de la réponse. L'orchestration relie les outils ; l'automatisation exécute des tâches répétitives ; la réponse applique une procédure contrôlée. TheHive fournit la gestion collaborative des alertes et des cas, tandis que Cortex exécute des analyseurs sur les observables [9], [10].

L'automatisation ne doit pas supprimer le contrôle : une règle mal calibrée peut bloquer un utilisateur légitime ou isoler un service critique. Pour cette raison, les actions sont limitées, journalisées, temporisées et associées à un mécanisme de retour arrière.

1.6 Threat Intelligence

La CTI transforme des données sur les menaces en connaissance exploitable. Un indicateur de compromission peut être une adresse IP, un domaine, une URL, un hachage ou un motif. MISP permet de structurer, corréler et partager ces indicateurs au moyen d'événements et de taxonomies [11], [12].

Dans la chaîne étudiée, TheHive extrait un observable d'une alerte, Cortex l'interroge auprès de services comme VirusTotal ou AbuseIPDB, et MISP fournit un contexte de menace. Un résultat d'enrichissement n'est toutefois pas une preuve autonome : sa date, sa source, son taux de confiance et le contexte local doivent être examinés.

1.7 OWASP Top 10

L'OWASP Top 10 :2021 constitue un document de sensibilisation aux risques applicatifs majeurs [4]. Ses catégories sont résumées dans le tableau 1.1.

Code	**Catégorie**	**Risque principal**
A01	Broken Access Control	Accès à des ressources ou actions sans autorisation suffisante.
A02	Cryptographic Failures	Exposition de données par chiffrement absent, faible ou mal employé.

Code	Catégorie	Risque principal
A03	Injection	Interprétation d'une entrée non fiable comme commande, requête ou script.
A04	Insecure Design	Absence de contrôles de sécurité dès la conception.
A05	Security Misconfiguration	Paramètres par défaut, services inutiles ou informations de diagnostic exposées.
A06	Vulnerable and Outdated Components	Utilisation de composants affectés par des vulnérabilités connues.
A07	Identification and Authentication Failures	Authentification, session ou récupération de compte insuffisamment protégée.
A08	Software and Data Integrity Failures	Confiance injustifiée dans un logiciel, une mise à jour ou une donnée.
A09	Security Logging and Monitoring Failures	Journalisation ou alerte insuffisante, retardant la détection.
A10	Server-Side Request Forgery	Requête serveur déclenchée vers une destination contrôlée par l'attaquant.

Tableau 1.1 : Catégories de l'OWASP Top 10 :2021

DVWA est une application volontairement vulnérable adaptée à la formation. Elle permet d'observer des attaques telles que l'injection SQL, le XSS, la traversée de répertoires et la force brute. Il faut cependant distinguer la catégorie de risque et le module pédagogique : certains rapprochements, comme l'emploi du contournement CSP pour illustrer A08, sont des approximations de laboratoire et non une équivalence normative.

Conclusion

Le SOC transforme des traces dispersées en décisions de sécurité. Le SIEM assure la visibilité et la corrélation ; le SOAR organise la réponse ; la CTI apporte le contexte ; l'OWASP Top 10 structure la couverture applicative. Le chapitre suivant traduit ces principes en exigences et en architecture technique.

Chapitre 2

Analyse et conception du laboratoire SOC

Plan du chapitre

1. Cahier des charges
2. Analyse des besoins
3. Choix des outils
4. Architecture générale et description des flux
5. Diagramme du flux de données et plan d'adressage IP
6. Risques de conception et contrôles

Introduction

Ce chapitre transforme l'objectif général en exigences vérifiables. Il décrit le périmètre, justifie les outils, présente l'architecture fournie et formalise les flux et l'adressage.

2.1 Cahier des charges

Le laboratoire doit fonctionner sur un poste VMware Workstation et isoler les activités offensives dans un réseau privé. Il doit collecter les journaux Linux, Windows, Apache et pfSense ; détecter des scénarios représentatifs ; centraliser les alertes dans Wazuh ; transmettre les événements majeurs à TheHive ; enrichir les observables avec Cortex et MISP ; et conserver les éléments nécessaires à une investigation reproductible.

Le périmètre exclut toute attaque dirigée vers un système tiers. Toutes les actions sont exécutées sur les machines du laboratoire. Les clés API, mots de passe et secrets ne doivent pas être reproduits dans le mémoire.

2.2 Analyse des besoins

2.2.1 Besoins fonctionnels

- ✓ router et filtrer les communications avec pfSense ;
- ✓ collecter les événements par agents et syslog ;
- ✓ décoder, corréler et prioriser les alertes ;
- ✓ surveiller l'intégrité des fichiers et l'inventaire de vulnérabilités ;
- ✓ créer des alertes et des cas dans TheHive ;
- ✓ analyser des IOC avec Cortex et les corréler avec MISP ;
- ✓ simuler les attaques prévues depuis Kali Linux ;
- ✓ bloquer temporairement une adresse source après une alerte critique.

2.2.2 Besoins non fonctionnels

La solution doit être ouverte, modulaire, reproductible et suffisamment documentée pour être reconstruite. Les événements doivent être horodatés, les échanges limités aux ports nécessaires et les secrets séparés des fichiers publiables. Le laboratoire doit également rester observable en cas d'échec : journaux de service, tests de ports et commandes de validation sont intégrés à la méthode de diagnostic.

2.3 Choix des outils

Composant	Fonction retenue	Justification
pfSense	Pare-feu, routage, NAT, segmentation, syslog	Administration centralisée des flux et visibilité sur les blocages.
Wazuh	SIEM/HIDS, agents, FIM, vulnérabilités, règles	Plateforme ouverte combinant collecte, analyse hôte et tableau de bord.
TheHive	Alertes, cas, tâches et observables	Gestion structurée du cycle de vie d'un incident.
Cortex	Analyseurs et enrichissement	Exécution contrôlée d'analyses externes sur les IOC.
MISP	Base et partage de renseignement	Modèle structuré d'événements et d'indicateurs corrélables.
Kali Linux	Génération des scénarios	Distribution adaptée aux outils de test autorisés.
Ubuntu Server/DVWA	Cible Linux et web	Exposition contrôlée de services SSH, FTP, Apache et d'une application vulnérable.
Windows Server 2019	AD, RDP, journaux et FIM	Validation de la supervision Windows et des événements d'authentification.

Tableau 2.2 : Rôle des composants du laboratoire

2.4 Architecture générale

La figure 2.1 reprend l'image d'architecture fournie. pfSense constitue la passerelle du LAN. Kali génère les activités offensives vers Ubuntu/DVWA et Windows Server. Les agents transmettent les journaux à Wazuh ; les alertes qualifiées sont envoyées à TheHive ; Cortex et MISP enrichissent l'investigation.

Le document source mentionne cinq machines principales, TheHive et Cortex partageant l'adresse `192.168.100.80`. MISP est intégré à cette couche de renseignement ; selon les ressources disponibles, il peut être colocalisé ou déployé sur une VM dédiée. Le choix de colocalisation réduit le coût de la maquette mais augmente le risque d'indisponibilité commune.

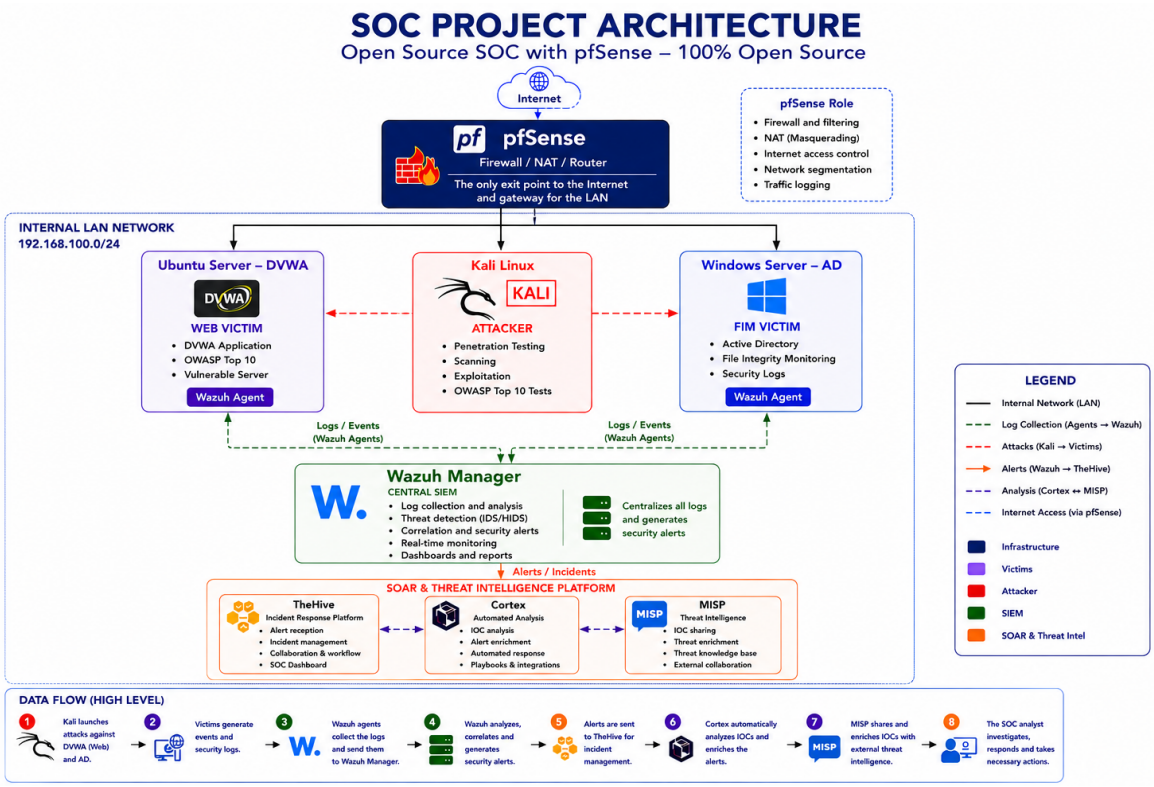


Figure 2.1 : Architecture complète du laboratoire SOC fournie avec le projet

2.4.1 Description des flux

1. Kali envoie une requête ou une tentative d'authentification à une cible du laboratoire.
2. La cible ou pfSense produit un journal local.
3. L'agent Wazuh ou syslog transmet le journal au Manager.
4. Le décodeur extrait les champs et la règle attribue un niveau.
5. Les alertes de niveau supérieur ou égal à 10 sont envoyées à TheHive.
6. L'analyste transforme l'alerte en cas et extrait les observables.
7. Cortex et MISP apportent réputation, corrélation et contexte.
8. Une réponse manuelle ou active contient l'incident.

2.5 Diagramme du flux de données

Kali Linux ⟶ Cible / pfSense ⟶ Journal

⇓

Agent ou syslog ⟶ Wazuh Manager ⟶ Règle et corrélation

⇓

TheHive ⟷ Cortex ⟷ MISP ⟶ Décision / réponse

Figure 2.2 : Reproduction synthétique du flux de détection et de réponse

2.6 Plan d'adressage IP

Machine	Adresse	Rôle	Ports principaux

Tableau 2.4 : Plan d'adressage du réseau privé 192.168.100.0/24

2.7 Risques de conception et contrôles

Les principaux risques sont la sortie accidentelle du trafic offensif, la perte de synchronisation temporelle, la saturation du stockage, la fuite de clés API et le blocage intempestif par réponse active. Ils sont réduits par le réseau Host-only, des adresses statiques, la limitation des sources, la rotation des journaux, la révocation des clés et un délai de blocage de 600 secondes.

Conclusion

L'architecture répond au besoin de visibilité multi-source et sépare clairement attaque, collecte, analyse et réponse. Le chapitre suivant décrit sa mise en œuvre et les incidents techniques rencontrés.

Mise en œuvre du laboratoire

Plan du chapitre

1. Installation de VMware Workstation
2. Configuration de pfSense
3. Déploiement de Wazuh
4. Installation de Windows Server 2019
5. Installation d'Ubuntu Server, de DVWA et de Kali Linux
6. Déploiement de TheHive
7. Déploiement de Cortex
8. Déploiement de MISP
9. Intégration des composants et démarche de diagnostic

Introduction

La réalisation a suivi un ordre allant du réseau vers les services de sécurité. Cette progression réduit les causes possibles d'une panne : connectivité, port, service, journal, décodeur, règle, puis intégration.

3.1 Installation de VMware Workstation

Un réseau VMnet1 de type Host-only a été retenu afin d'isoler les essais. Les options de DHCP VMware ont été désactivées et des adresses statiques ont été attribuées. Chaque VM a été dimensionnée selon son rôle, avec des instantanés avant les changements majeurs. La passerelle par défaut des machines du LAN est `192.168.100.254`.

Les premiers essais ont montré des hôtes ne possédant qu'une adresse IPv6 locale et une absence d'accès Internet. La correction a consisté à supprimer le DHCP parasite, configurer IPv4 avec netplan ou l'interface système et définir la passerelle WAN de pfSense comme route par défaut, sans attacher de passerelle au LAN.

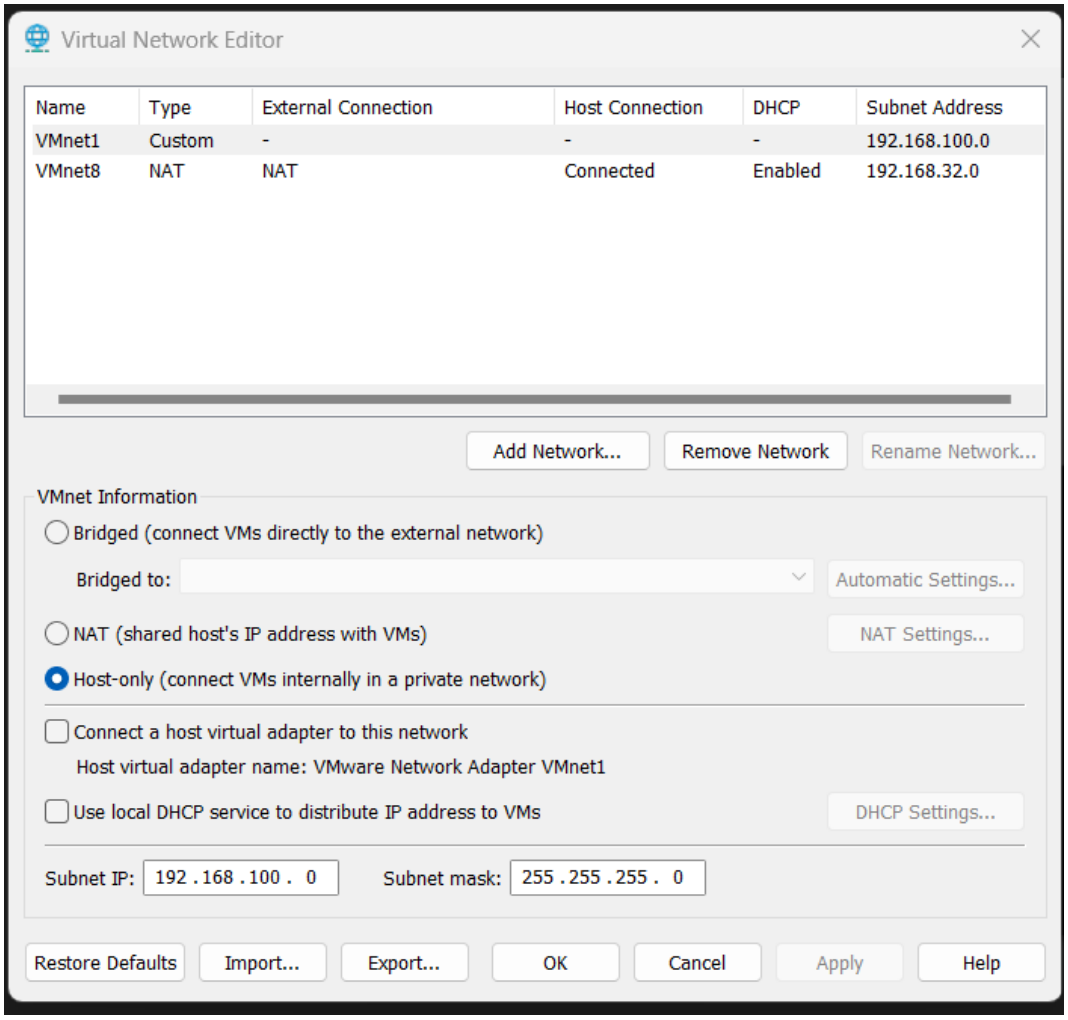


Figure 3.1 : Configuration du réseau Host-only VMnet1 dans VMware Workstation

3.2 Configuration de pfSense

pfSense dispose d'une interface WAN reliée au réseau fournissant l'accès externe contrôlé et d'une interface LAN sur `192.168.100.254/24`. Le NAT sortant masque les adresses privées. Les règles de pare-feu autorisent uniquement les flux nécessaires à l'administration, aux mises à jour et aux intégrations.

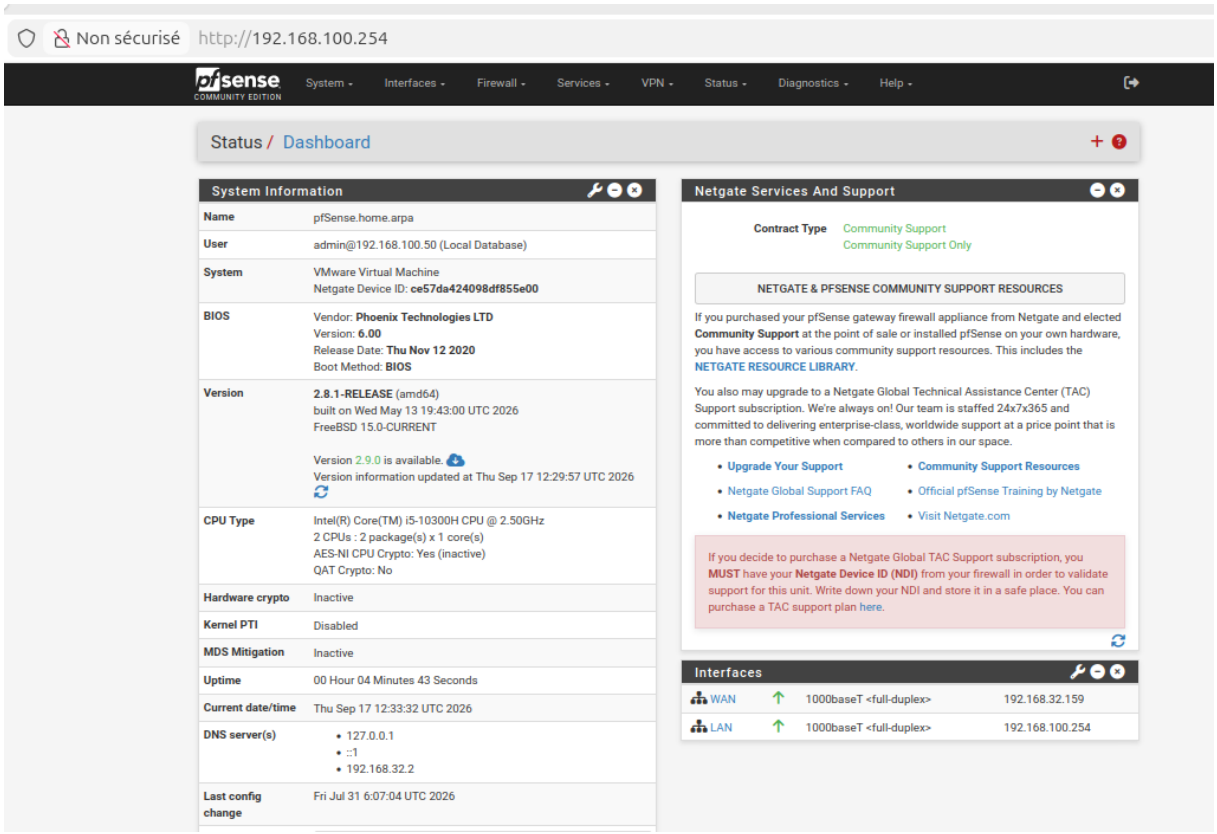


Figure 3.2 : Interfaces WAN/LAN et tableau de bord de pfSense

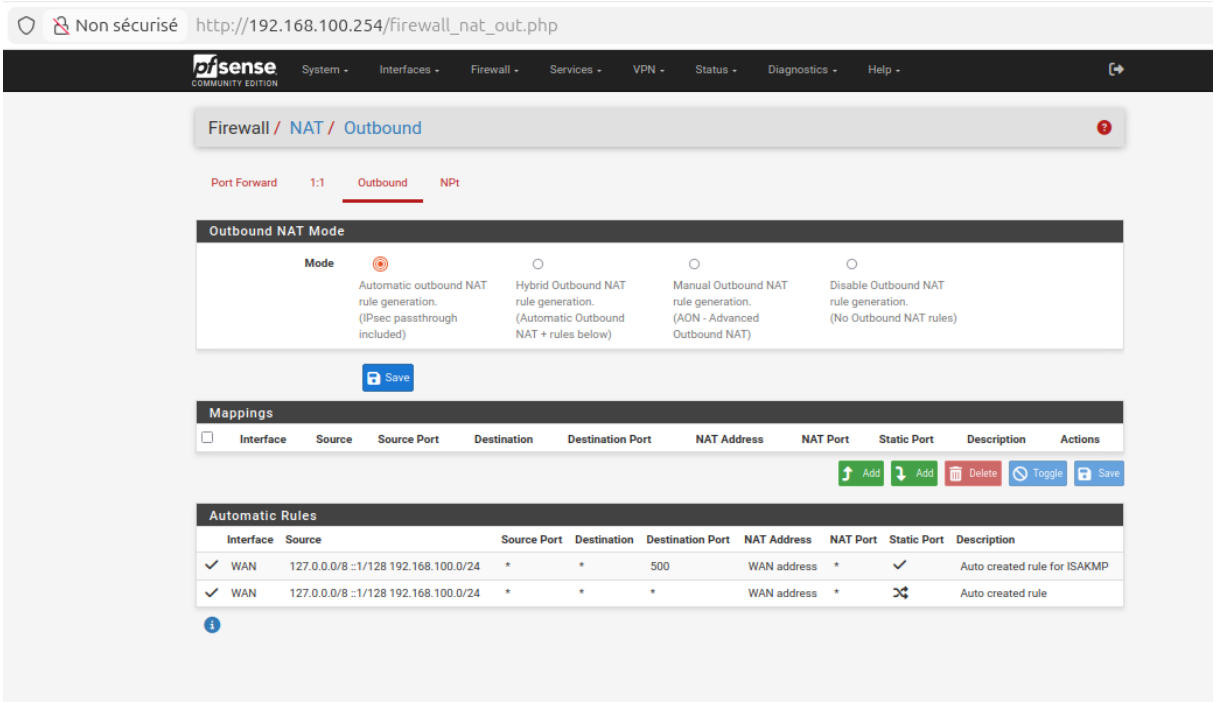


Figure 3.3 : Règles de filtrage et configuration NAT de pfSense

La journalisation distante est activée vers `192.168.100.50:514/UDP`. Une capture avec `tcpdump` a confirmé l'arrivée des datagrammes. Le format reçu ne correspondant pas exactement au décodeur officiel, un décodeur `pf-custom` et les règles 100160 à 100162 ont été créés. Cette correction rappelle qu'une réception réseau réussie ne garantit pas un décodage correct.

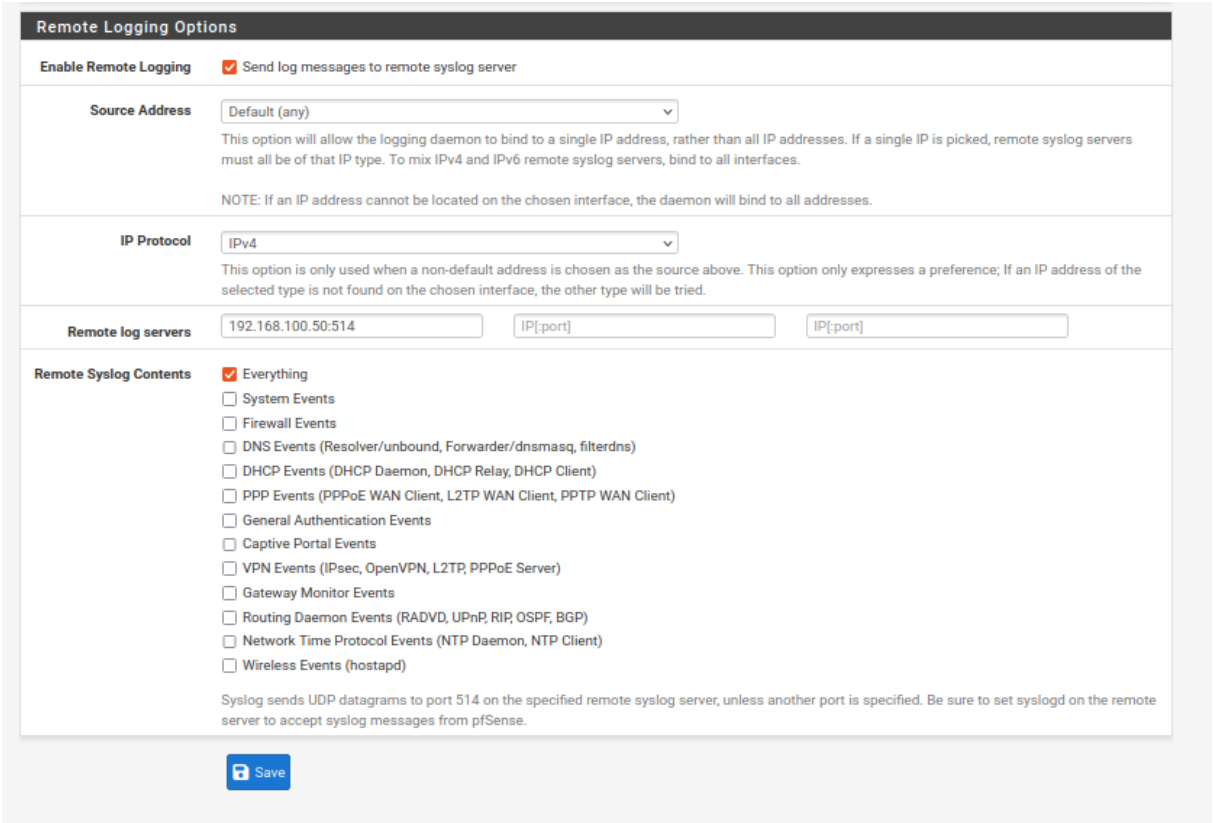


Figure 3.4 : Configuration du transfert syslog de pfSense vers Wazuh

3.3 Déploiement de Wazuh

Le Wazuh Manager et le Dashboard sont installés sur Ubuntu Server à l'adresse `192.168.100.50`. La version documentée dans les essais est Wazuh 4.12.0. Les agents communiquent avec le Manager sur les ports de collecte et d'enrôlement prévus par la documentation officielle [8].

L'agent Ubuntu a dû être installé dans la même version que le Manager : l'utilisation d'un paquet plus récent provoquait une incompatibilité. Sous Windows, un message *Duplicate name* a été résolu par la suppression de l'ancien enregistrement et l'import manuel d'une nouvelle clé avec `manage_agents`.

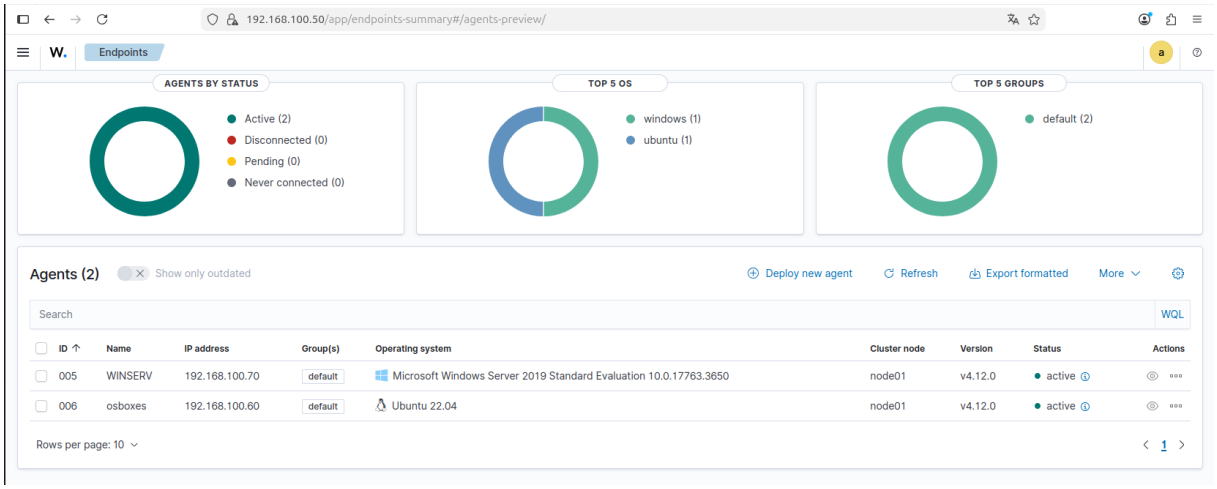


Figure 3.5 : Vue générale du Dashboard Wazuh et état des agents

3.3.1 Sources collectées

Les sources principales sont les journaux d'authentification Linux, les événements Windows, les changements FIM, les journaux Apache de DVWA et les messages syslog pfSense. Le journal Apache du conteneur est exposé sur l'hôte par un volume, puis déclaré dans l'agent :

```
<localfile>
  <log_format>apache</log_format>
  <location>/var/log/dvwa/access.log</location>
</localfile>
```

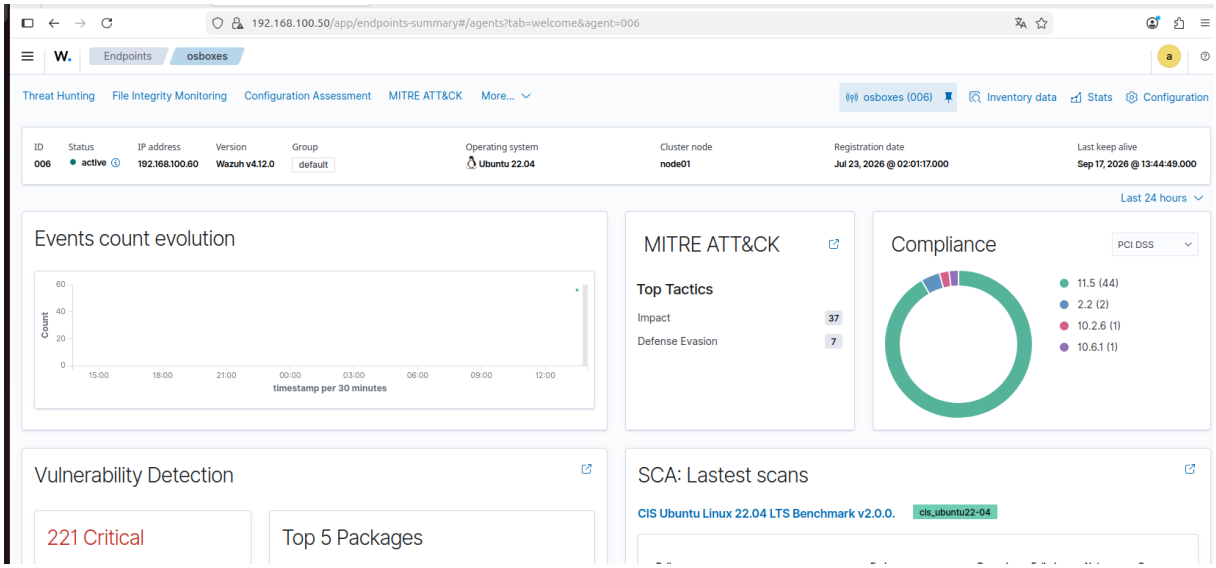


Figure 3.6 : Enrôlement de l'agent Ubuntu Server dans Wazuh

3.4 Installation de Windows Server 2019

Windows Server 2019 est configuré à l'adresse `192.168.100.70`. Le rôle Active Directory Domain Services fournit un contexte d'identité et le service RDP sert aux essais d'authentification. Les règles du pare-feu Windows nécessaires à RDP et, pendant les tests contrôlés, aux services SMB ont été activées.

L'agent Wazuh collecte les événements de sécurité, notamment l'Event ID 4625 relatif aux ouvertures de session échouées. Le module FIM surveille des emplacements sélectionnés ; les chemins critiques doivent être ciblés pour éviter un volume inutile et respecter les performances du serveur.

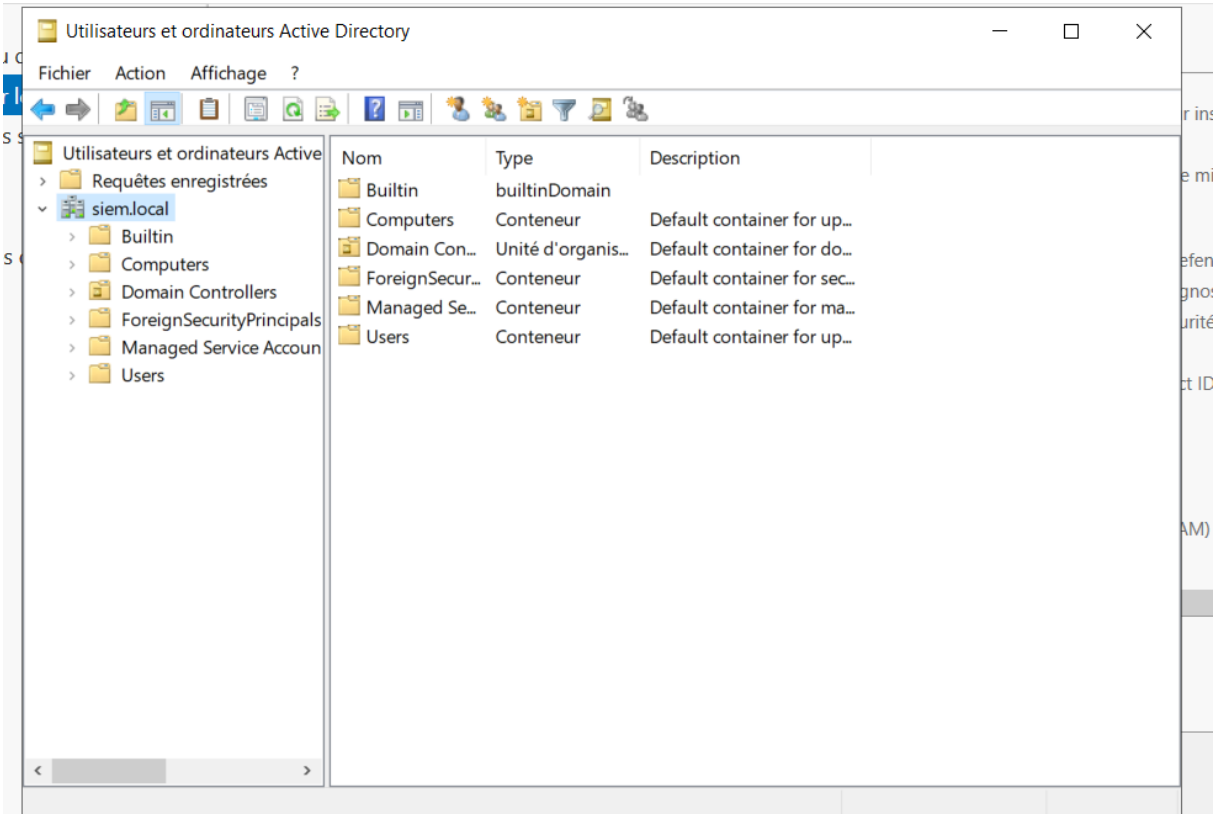


Figure 3.7 : Installation d'Active Directory Domain Services

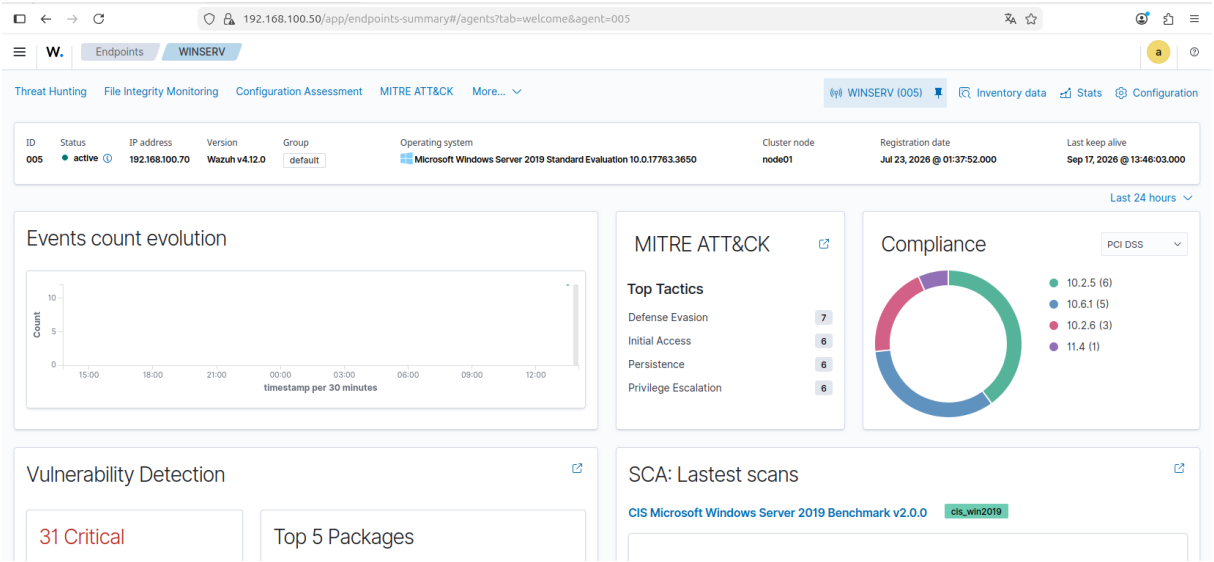


Figure 3.8 : Enrôlement de Windows Server 2019 dans Wazuh

3.5 Installation d'Ubuntu Server et de DVWA

Ubuntu 22.04 LTS, à l'adresse `192.168.100.60`, héberge SSH, vsftpd, Apache, Docker et DVWA. Le conteneur est publié sur le port 8080. Les journaux Apache sont montés dans `/var/log/dvwa` afin que l'agent Wazuh puisse les lire.

```
sudo apt install apache2 docker.io -y
```

```
sudo systemctl enable --now apache2 docker
sudo mkdir -p /var/log/dvwa
sudo docker run -d --name dvwa --restart unless-stopped -p 8080:80 \
  -v /var/log/dvwa:/var/log/apache2 vulnerables/web-dvwa
```

L'option de redémarrage automatique corrige les interruptions ponctuelles relevées lors du premier jalon d'essai. DVWA reste strictement confiné au laboratoire et ne doit jamais être exposé à Internet.

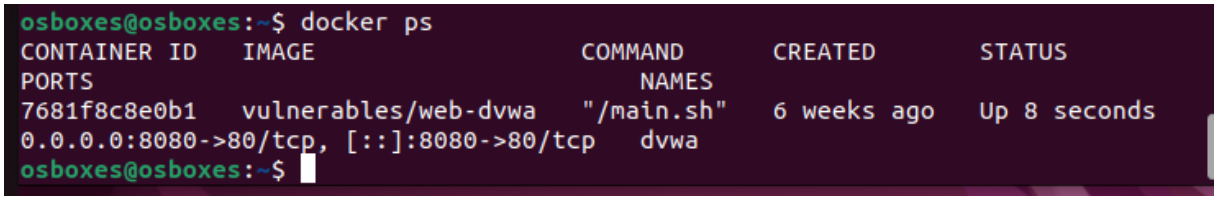


Figure 3.9 : Déploiement du conteneur Docker DVWA sur Ubuntu Server

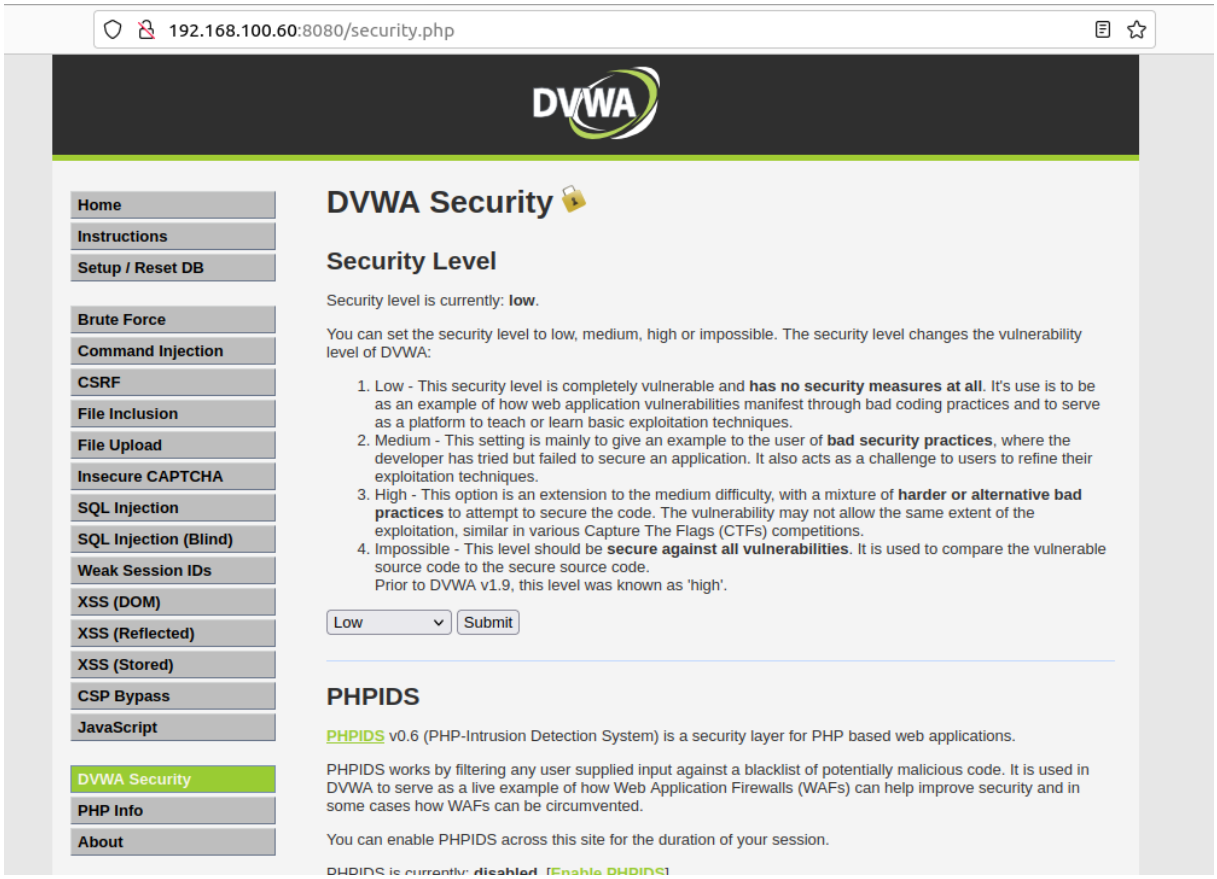


Figure 3.10 : Interface DVWA et configuration du niveau de sécurité

3.6 Installation de Kali Linux

Kali Linux, à l'adresse `192.168.100.100`, regroupe les outils de test : Nmap pour la reconnaissance, Hydra pour SSH, Ncrack pour RDP, un client FTP, `curl` et un navigateur pour DVWA. Les dictionnaires sont courts et conçus uniquement pour provoquer des événements contrôlés.

3.7 Déploiement de TheHive

TheHive est accessible sur `192.168.100.80:9000`. Une organisation de laboratoire et un compte de service dédié à Wazuh ont été créés. Le script `custom-w2thive.py`, placé dans le répertoire d'intégration Wazuh, transforme l'alerte JSON en alerte TheHive. Le seuil de niveau 10 évite de transférer les événements courants.

```
<integration>
  <name>custom-w2thive</name>
  <hook_url>http://192.168.100.80:9000</hook_url>
  <api_key>VALEUR_CONSERVEE_HORS_DU_RAPPORT</api_key>
  <alert_format>json</alert_format>
  <level>10</level>
</integration>
```

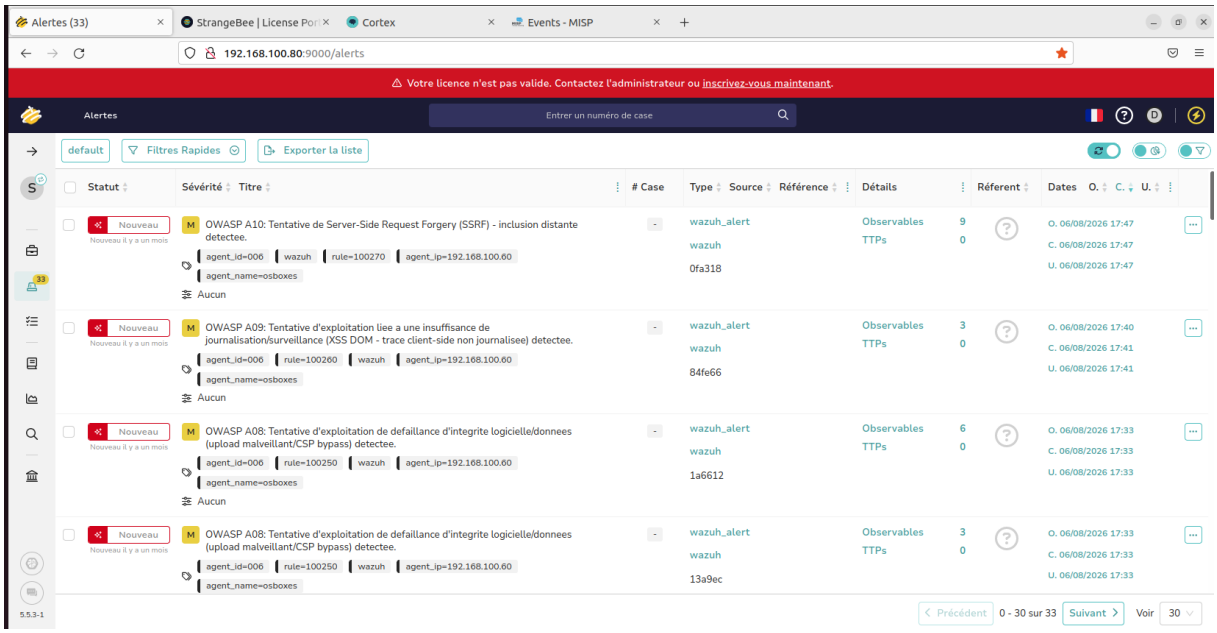


Figure 3.11 : Interface TheHive et vue des alertes sur le port 9000

3.8 Déploiement de Cortex

Cortex est publié sur le port 9001 et associé à l'organisation `SOC-Lab`. Deux profils sont distingués : un administrateur d'organisation et un compte de service utilisé par TheHive. Les analyseurs testés comprennent AbuseIPDB et VirusTotal.

Une migration Elasticsearch avait laissé l'alias `cortex` absent et une base initiale incohérente. La recréation de l'alias, puis, dans l'environnement de test uniquement, la réinitialisation de l'index corrompu ont permis le bootstrap. Toute opération de suppression d'index doit être précédée d'une sauvegarde dans un contexte réel.

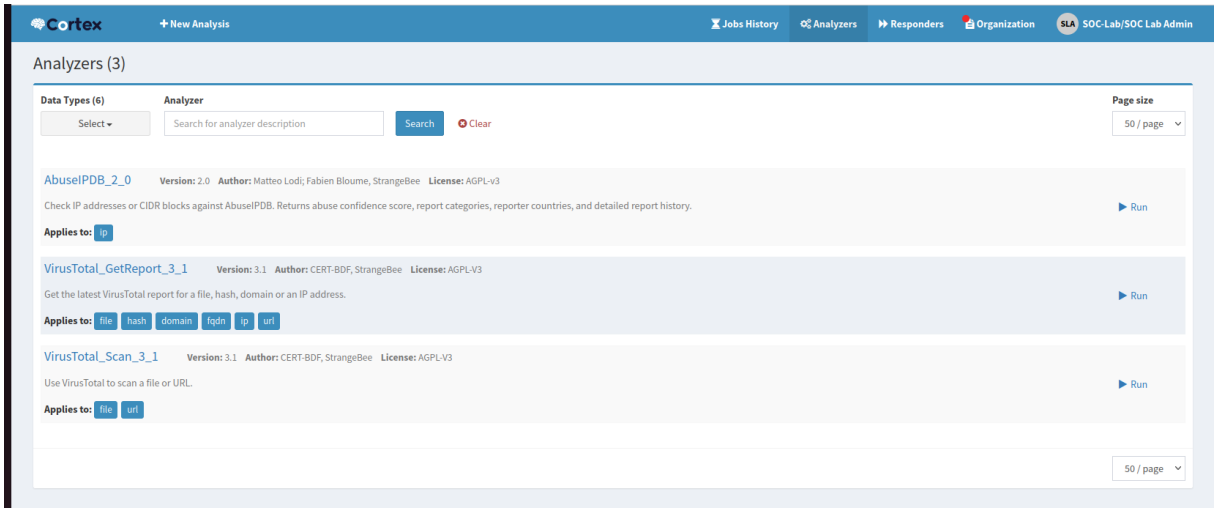


Figure 3.12 : Interface Cortex et liste des analyseurs disponibles

3.9 Déploiement de MISP

MISP est connecté à TheHive comme serveur `misp-local`. Un événement de test intitulé *Test Event – Mini SOC Lab*, contenant l'observable `8.8.8.8`, a été publié. Il est apparu comme alerte MISP dans TheHive, puis l'observable a été soumis aux analyseurs Cortex. Ce test valide la circulation MISP → TheHive → Cortex.

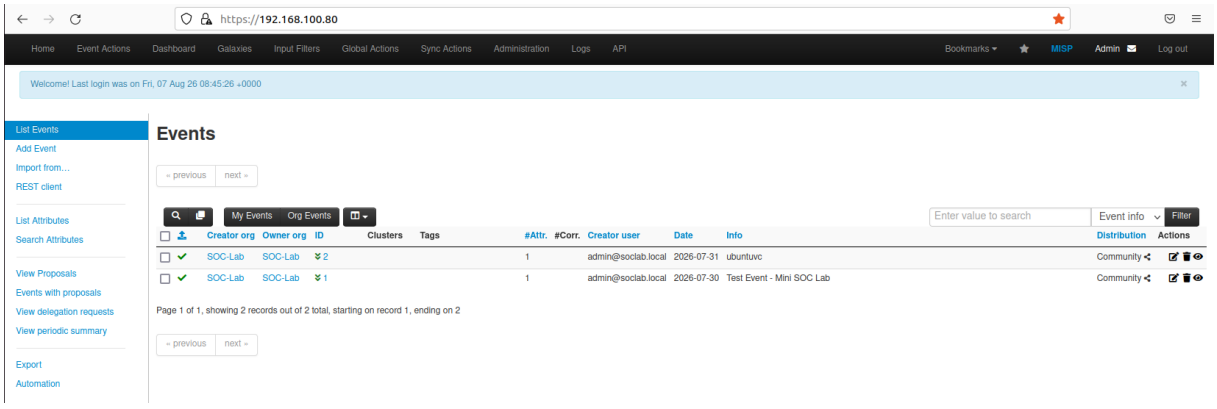


Figure 3.13 : Événements de renseignement publiés dans MISP

3.10 Intégration des composants

Les principales intégrations sont récapitulées à l'aide d'une matrice de validation, en distinguant les éléments effectivement visibles dans les captures des résultats non documentés graphiquement.

Liaison	**Mécanisme**	**Validation**
pfSense → Wazuh	Syslog UDP/514, décodeur et règles	Paquets reçus et règles 100160–100162 visibles.

Liaison	**Mécanisme**	**Validation**
Agents → Wazuh	Agent Wazuh	Événements Linux, Windows, Apache et FIM reçus.
Wazuh → TheHive	Script Python et API	Alertes Wazuh visibles dans TheHive.
TheHive ↔ Cortex	Connecteur API	Test de configuration réussi et analyseurs disponibles.
MISP → TheHive	Connecteur / synchronisation	Événement MISP publié ; la synchronisation vers TheHive n'est pas démontrée par une capture dédiée.

Tableau 3.1 : Validation des intégrations du laboratoire

3.10.1 Démarche de diagnostic

Lorsqu'une intégration échoue, la séquence suivante est appliquée : vérifier l'état de la VM, tester le ping lorsque celui-ci est autorisé, tester le port avec `nc` ou `curl`, contrôler le service, consulter le journal, puis seulement modifier la configuration. Cette méthode a permis de distinguer l'erreur réseau temporaire vers TheHive des conflits de règles Wazuh.

Conclusion

Le déploiement fournit une chaîne cohérente allant des sources aux alertes de sécurité et à leur enrichissement. Les difficultés rencontrées ont surtout concerné la cohérence réseau, les versions, les identités d'agent et le décodage. Le chapitre suivant mesure le comportement du laboratoire face aux scénarios définis.

Tests et validation

Plan du chapitre

1. Validation des attaques par force brute SSH et RDP
2. Validation de la surveillance d'intégrité des fichiers
3. Scan réseau et détection des vulnérabilités
4. Reconnaissance contre pfSense
5. Validation de l'OWASP Top 10 sur DVWA
6. Active Response
7. Cartographie MITRE ATT&CK
8. Discussion des résultats

Introduction

Chaque test est mené dans le réseau isolé et documenté selon la même structure : objectif, environnement, procédure, journaux, alertes, résultat et interprétation. Les captures originales du laboratoire sont placées immédiatement après l'installation, la configuration ou le résultat qu'elles documentent. Lorsqu'une preuve n'est pas disponible, le texte le signale explicitement afin d'éviter de présenter un résultat non vérifié comme démontré.

4.1 Scénario 1 : attaque SSH par force brute

Objectif. Vérifier la détection d'une succession de mots de passe erronés sur Ubuntu. **Environnement.** Kali `192.168.100.100` vers Ubuntu `192.168.100.60`. **Outils.** Hydra, OpenSSH et agent Wazuh.

```
printf '123456\npassword\nadmin\nosboxes\ntest123\nqwerty\n' > /tmp/wordlist.txt
hydra -l osboxes -P /tmp/wordlist.txt ssh://192.168.100.60
```

Les journaux PAM et SSH ont produit les règles 5503 et 5760, toutes deux visibles dans la capture, au niveau 5. Le jeu de captures fourni ne permet pas de confirmer séparément la règle 5758. L'adresse source était `192.168.100.100`. Le scénario est détecté ; la répétition des événements confirme la force brute, cartographiée sur T1110.

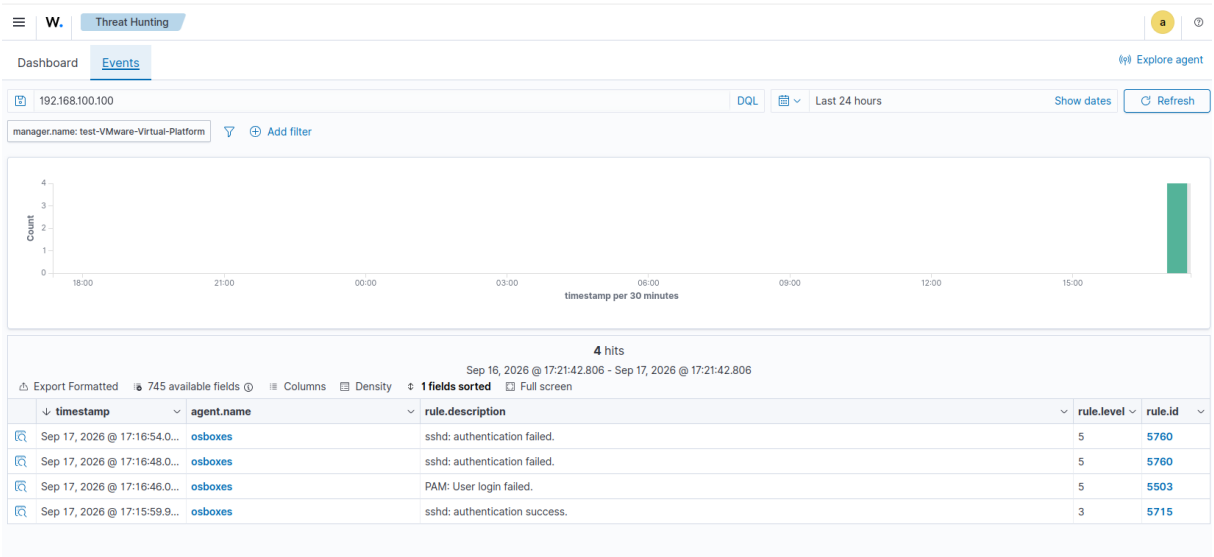


Figure 4.1 : Détection Wazuh de la force brute SSH – règles 5503 et 5760 visibles

4.2 Scénario 2 : attaque RDP par force brute

Objectif. Tester les événements Windows d'authentification et le verrouillage de compte. **Environnement.** Kali vers Windows Server `192.168.100.70`. **Outils.** Ncrack, RDP, journal Security et agent Wazuh.

```
ncrack -u Administrateur -P /tmp/wordlist.txt rdp://192.168.100.70
```

Wazuh a associé les échecs d'authentification Windows à la règle 60122, niveau 5, visible dans la capture. La règle 60115 n'est pas visible dans le jeu de captures fourni et n'est donc pas retenue comme preuve graphique. Les sources indiquent 381 événements sur 24 heures. Le test est détecté et confirme l'efficacité de la politique de verrouillage. La technique MITRE associée est T1110.

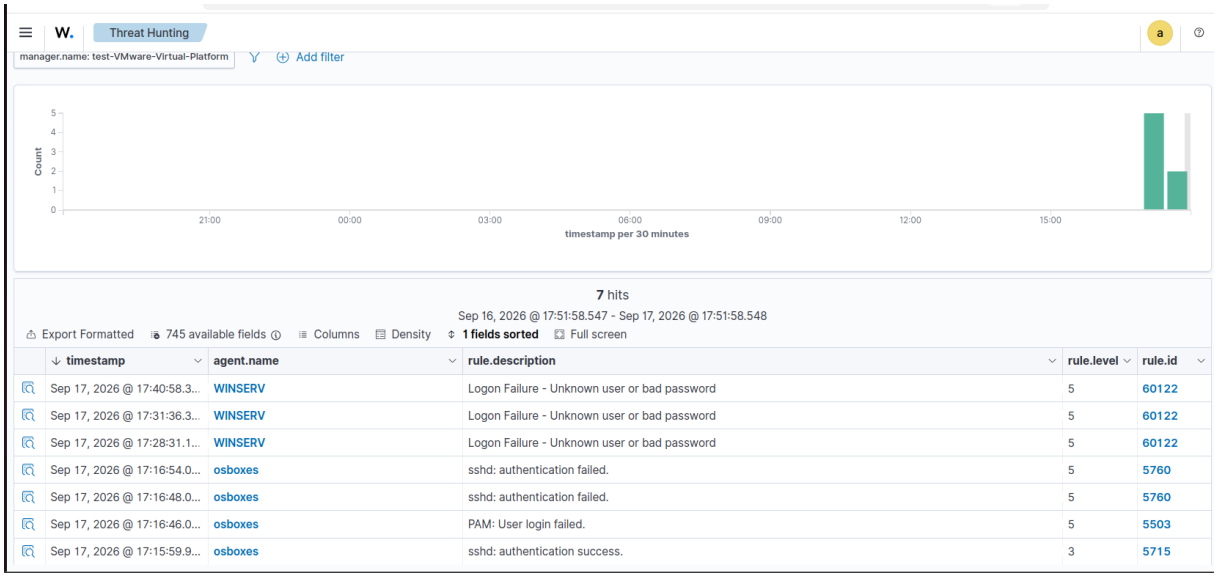


Figure 4.2 : Détection Wazuh de la force brute RDP – règle 60122 visible

4.3 Scénario 3 : altération de fichiers avec FIM

Objectif. Détecter l'ajout, la modification et la suppression de fichiers. **Environnement.** Répertoire `/home/osboxes` surveillé en temps réel. **Outils.** vsftpd, client FTP et module syscheck.

```
<directories realtime="yes">/home/osboxes</directories>
ftp> put /tmp/malicious_upload.txt
ftp> delete malicious_upload.txt
```

La capture montre les règles 550 et 554, correspondant respectivement au changement d'empreinte et à l'ajout du fichier. La règle 553 n'est pas visible dans cette preuve graphique. Les sources comptabilisent 2,574 événements FIM sur 24 heures, ce qui confirme la détection mais montre qu'un périmètre trop large augmente le bruit. Le scénario correspond à T1565.

Un test de filtrage crée `fichier_critique.txt` et `fichier_normal.txt`. La règle 100170 élève uniquement le premier au niveau 12 ; il est transmis à TheHive, contrairement au second resté au niveau 7.

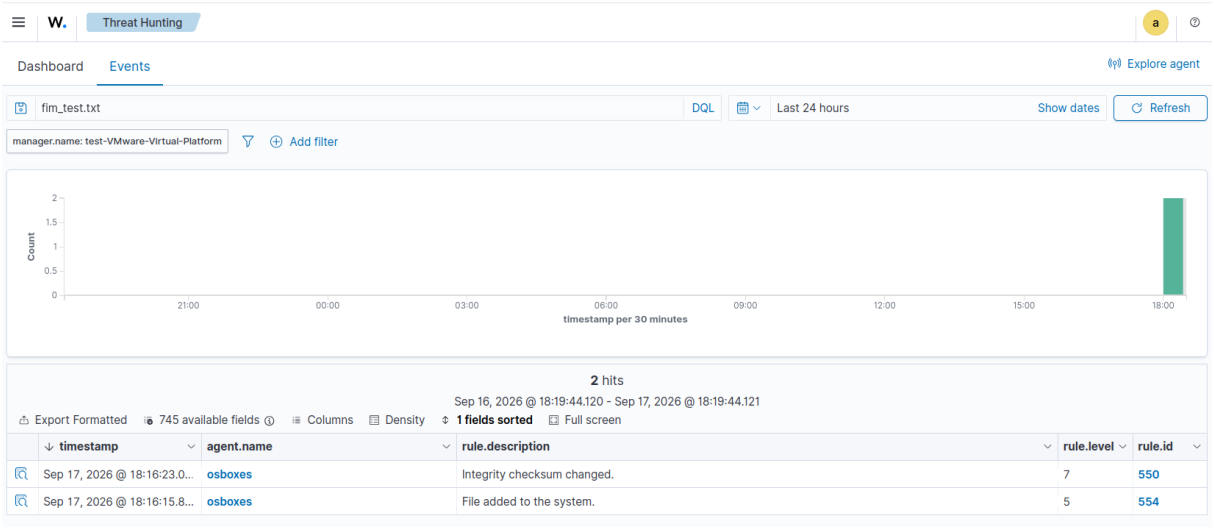


Figure 4.3 : Alertes File Integrity Monitoring – règles 550 et 554 visibles

4.4 Scénario 4 : scan réseau et vulnérabilités

Objectif. Inventorier les services et comparer l'inventaire logiciel aux CVE. **Outils.** Nmap et module Vulnerability Detection.

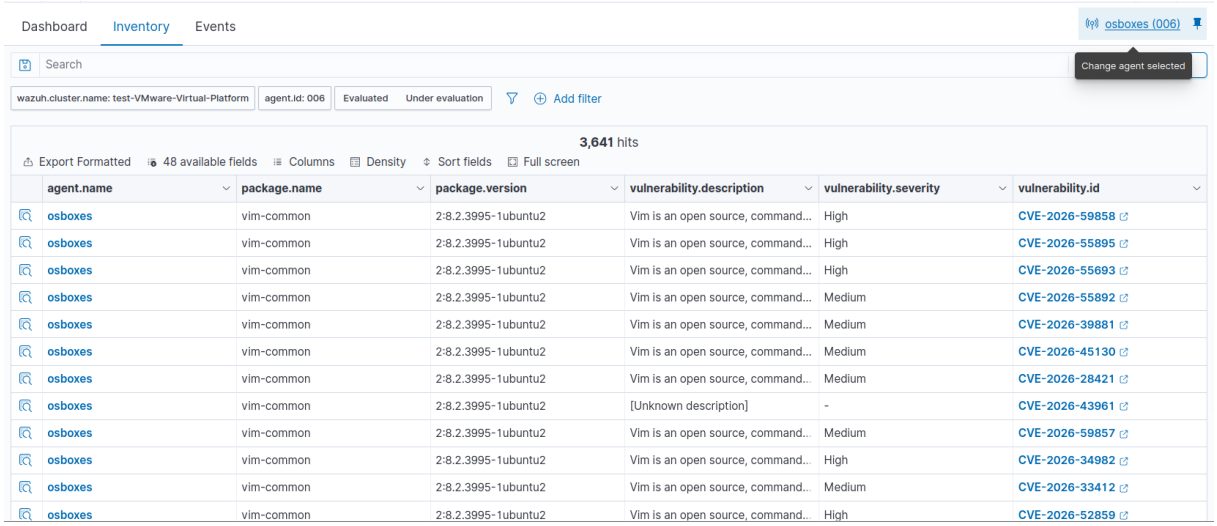
```
nmap -sn 192.168.100.0/24
nmap -sV -sC -A -T4 192.168.100.60
```

Le tableau 4.1 reprend les volumes consignés. Ils représentent des occurrences de détection et non nécessairement des vulnérabilités uniques ; ils doivent être dédupliqués et confirmés avant remédiation.

Hôte	Critique	Élevée	Moyenne	Faible
Ubuntu VC	435	3,251	3,905	135
Windows Server 2019	15	496	252	3

Tableau 4.1 : Occurrences de vulnérabilités rapportées par Wazuh

Le scan actif relève de T1595. La détection de vulnérabilités est une analyse de posture : elle ne prouve pas l'exploitation d'une CVE.



agent.name	package.name	package.version	vulnerability.description	vulnerability.severity	vulnerability.id
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	High	CVE-2026-59858
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	High	CVE-2026-55895
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	High	CVE-2026-55693
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	Medium	CVE-2026-55892
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	Medium	CVE-2026-39881
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	Medium	CVE-2026-45130
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	Medium	CVE-2026-28421
osboxes	vim-common	2:8.2.3995-1ubuntu2	[Unknown description]	-	CVE-2026-43961
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	Medium	CVE-2026-59857
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	High	CVE-2026-34982
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	Medium	CVE-2026-33412
osboxes	vim-common	2:8.2.3995-1ubuntu2	Vim is an open source, command...	High	CVE-2026-52859

FIGURE 4.4 : Résultats du module Wazuh Vulnerability Detection

4.5 Scénario 5 : reconnaissance contre pfSense

Objectif. Vérifier la chaîne pfSense → syslog → Wazuh. **Procédure.**

```
nmap -Pn -sS -sV 192.168.100.254
```

La capture du scan indique les ports 53 et 80 ouverts et 998 ports filtrés sur les 1 000 ports examinés. Le décodeur personnalisé reconnaît `filterlog`. La règle 100160 qualifie l'événement et la règle 100161 identifie les connexions bloquées. La capture fournie montre ces deux règles ; la règle 100162 n'est pas visible et n'est donc pas utilisée comme preuve graphique. Le résultat est détecté et associé à T1595.001.

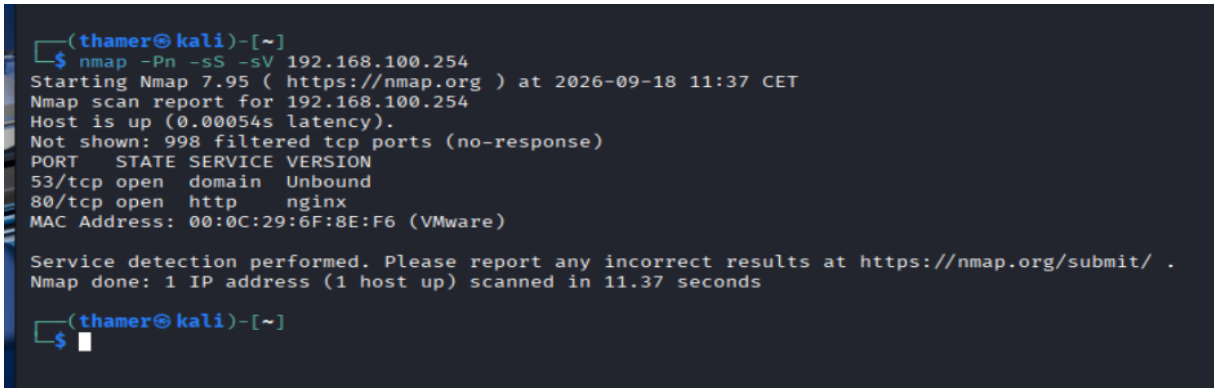
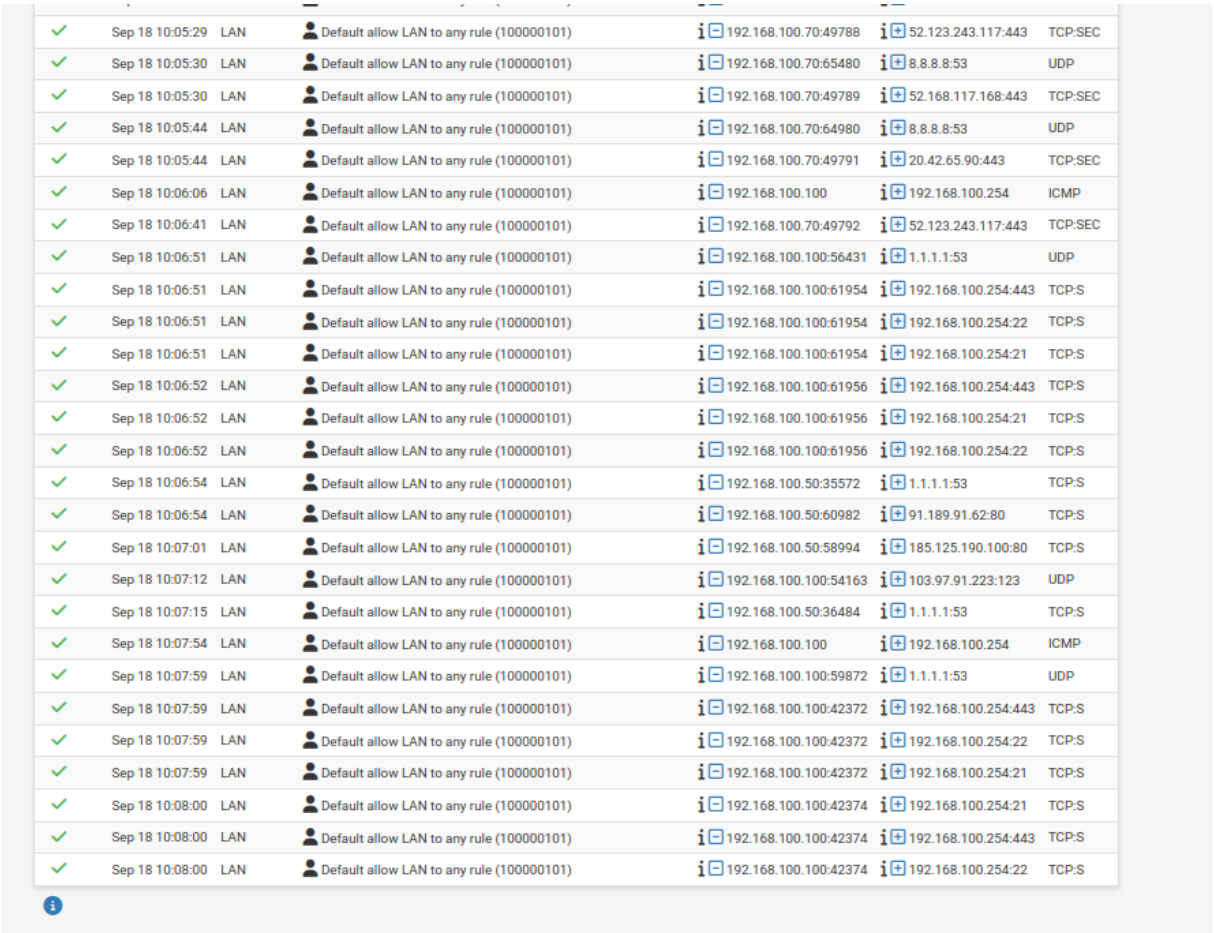
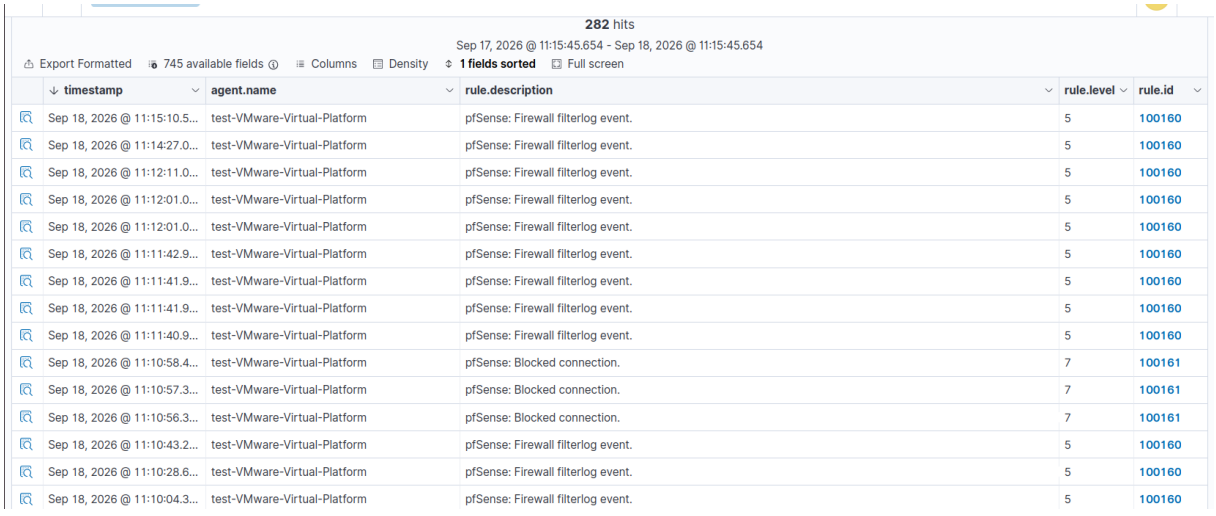


FIGURE 4.5 : Scan Nmap contre pfSense depuis Kali Linux



✓	Sep 18 10:05:29	LAN	Default allow LAN to any rule (100000101)	192.168.100.70:49788	52.123.243.117:443	TCP:SEC
✓	Sep 18 10:05:30	LAN	Default allow LAN to any rule (100000101)	192.168.100.70:65480	8.8.8.8:53	UDP
✓	Sep 18 10:05:30	LAN	Default allow LAN to any rule (100000101)	192.168.100.70:49789	52.168.117.168:443	TCP:SEC
✓	Sep 18 10:05:44	LAN	Default allow LAN to any rule (100000101)	192.168.100.70:64980	8.8.8.8:53	UDP
✓	Sep 18 10:05:44	LAN	Default allow LAN to any rule (100000101)	192.168.100.70:49791	20.42.65.90:443	TCP:SEC
✓	Sep 18 10:06:06	LAN	Default allow LAN to any rule (100000101)	192.168.100.100	192.168.100.254	ICMP
✓	Sep 18 10:06:41	LAN	Default allow LAN to any rule (100000101)	192.168.100.70:49792	52.123.243.117:443	TCP:SEC
✓	Sep 18 10:06:51	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:56431	1.1.1.1:53	UDP
✓	Sep 18 10:06:51	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:61954	192.168.100.254:443	TCP:S
✓	Sep 18 10:06:51	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:61954	192.168.100.254:22	TCP:S
✓	Sep 18 10:06:51	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:61954	192.168.100.254:21	TCP:S
✓	Sep 18 10:06:52	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:61956	192.168.100.254:443	TCP:S
✓	Sep 18 10:06:52	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:61956	192.168.100.254:21	TCP:S
✓	Sep 18 10:06:52	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:61956	192.168.100.254:22	TCP:S
✓	Sep 18 10:06:54	LAN	Default allow LAN to any rule (100000101)	192.168.100.50:35572	1.1.1.1:53	TCP:S
✓	Sep 18 10:06:54	LAN	Default allow LAN to any rule (100000101)	192.168.100.50:60982	91.189.91.62:80	TCP:S
✓	Sep 18 10:07:01	LAN	Default allow LAN to any rule (100000101)	192.168.100.50:58994	185.125.190.100:80	TCP:S
✓	Sep 18 10:07:12	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:54163	103.97.91.223:123	UDP
✓	Sep 18 10:07:15	LAN	Default allow LAN to any rule (100000101)	192.168.100.50:36484	1.1.1.1:53	TCP:S
✓	Sep 18 10:07:54	LAN	Default allow LAN to any rule (100000101)	192.168.100.100	192.168.100.254	ICMP
✓	Sep 18 10:07:59	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:59872	1.1.1.1:53	UDP
✓	Sep 18 10:07:59	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:42372	192.168.100.254:443	TCP:S
✓	Sep 18 10:07:59	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:42372	192.168.100.254:22	TCP:S
✓	Sep 18 10:07:59	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:42372	192.168.100.254:21	TCP:S
✓	Sep 18 10:08:00	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:42374	192.168.100.254:21	TCP:S
✓	Sep 18 10:08:00	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:42374	192.168.100.254:443	TCP:S
✓	Sep 18 10:08:00	LAN	Default allow LAN to any rule (100000101)	192.168.100.100:42374	192.168.100.254:22	TCP:S

Figure 4.6 : Journaux filterlog générés par pfSense après le scan



282 hits

Sep 17, 2026 @ 11:15:45.654 - Sep 18, 2026 @ 11:15:45.654

Export Formatted | 745 available fields | Columns | Density | **1 fields sorted** | Full screen

	timestamp	agent.name	rule.description	rule.level	rule.id
	Sep 18, 2026 @ 11:15:10.5...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:14:27.0...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:12:11.0...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:12:01.0...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:12:01.0...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:11:42.9...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:11:41.9...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:11:41.9...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:11:40.9...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:10:58.4...	test-VMware-Virtual-Platform	pfSense: Blocked connection.	7	100161
	Sep 18, 2026 @ 11:10:57.3...	test-VMware-Virtual-Platform	pfSense: Blocked connection.	7	100161
	Sep 18, 2026 @ 11:10:56.3...	test-VMware-Virtual-Platform	pfSense: Blocked connection.	7	100161
	Sep 18, 2026 @ 11:10:43.2...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:10:28.6...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160
	Sep 18, 2026 @ 11:10:04.3...	test-VMware-Virtual-Platform	pfSense: Firewall filterlog event.	5	100160

Figure 4.7 : Alertes pfSense reçues dans Wazuh – règles 100160 et 100161 visibles

4.6 Scénario 6 : OWASP Top 10 sur DVWA

4.6.1 Méthode commune

Pour chaque catégorie, la requête est exécutée sur DVWA, vérifiée dans `/var/log/dvwa/access.log`, testée avec `wazuh-logtest`, puis recherchée dans `alerts.json` et TheHive. Les règles de niveau 10

franchissent le seuil d'intégration. Cortex analyse les adresses, domaines, URL ou hachages pertinents ; MISP recherche une corrélation et conserve le contexte.

4.6.2 A01 – Broken Access Control

Le module File Inclusion accepte un chemin tel que `../../../../etc/passwd`. La règle 100190 recherche la traversée de répertoires dans l'URL après décodage Apache. Le scénario est conçu pour alimenter TheHive lorsque le seuil d'intégration est atteint ; la capture fournie documente directement les alertes visibles dans TheHive pour les événements effectivement transférés. Les protections sont une liste blanche, un contrôle d'autorisation serveur et la normalisation des chemins.

4.6.3 A02 – Cryptographic Failures

Le module Weak Session IDs illustre une valeur de session prévisible. La règle 100200 détecte l'accès répété au module et les motifs consignés. Cette détection signale une activité de test, mais ne démontre pas à elle seule la faiblesse cryptographique. Les mesures prioritaires sont des identifiants aléatoires, TLS et des algorithmes de hachage adaptés aux mots de passe.

4.6.4 A03 – Injection

Les essais couvrent l'injection SQL et le XSS réfléchi. Les règles 100180 et 100181 reconnaissent des motifs comme `UNION`, `SELECT`, `javascript:` ou `onerror=`. Après un premier jalon instable au 6 août 2026, le rapport complémentaire confirme l'extension des tests. Les requêtes paramétrées, la validation des entrées et l'encodage de sortie constituent les contrôles essentiels.

4.6.5 A04 – Insecure Design

Le module CSRF permet un changement d'état sans mécanisme anti-CSRF suffisamment robuste. La règle 100210 identifie l'URL et les paramètres correspondants. La conception sûre exige un modèle de menace, des jetons uniques, des cookies `SameSite` et une nouvelle authentification pour les opérations sensibles.

4.6.6 A05 – Security Misconfiguration

L'accès à `phpinfo.php` révèle versions, modules et chemins. La règle 100220 détecte cette ressource exposée. Lorsqu'elle est transférée, TheHive centralise l'alerte et permet à l'analyste de vérifier si l'accès est autorisé. La remédiation consiste à supprimer les pages de diagnostic, durcir les paramètres et contrôler régulièrement les configurations.



28 hits

Sep 17, 2026 @ 12:15:38.967 - Sep 18, 2026 @ 12:15:38.967

Export Formatted | 745 available fields | Columns | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 18, 2026 @ 12:15:28.1...	osboxes	OWASP A05: Tentative d'exploitation de mauvaise configuration de securite (exposition config/upload) detectee.	10	100220
Sep 18, 2026 @ 12:14:59.9...	osboxes	OWASP A04: Tentative d'exploitation de conception non securisee (CSRF/CAPTCHA bypass) detectee.	10	100210
Sep 18, 2026 @ 12:14:41.8...	osboxes	OWASP A03: Tentative d'injection SQL détectée.	10	100180
Sep 18, 2026 @ 12:14:27.8...	osboxes	OWASP A02: Tentative d'exploitation de session/crypto faible (Weak Session ID) detectee.	10	100200
Sep 18, 2026 @ 12:14:27.8...	osboxes	OWASP A02: Tentative d'exploitation de session/crypto faible (Weak Session ID) detectee.	10	100200
Sep 18, 2026 @ 12:13:57.7...	osboxes	OWASP A01: Tentative de contournement de controle d'acces (IDOR/Path Traversal/Forced Browsing) detectee.	10	100190

Figure 4.8 : Détection des attaques OWASP A01 à A05 dans Wazuh

4.6.7 A06 – Vulnerable and Outdated Components

L'accès à `setup.php` et l'inventaire de versions facilitent la recherche de CVE. La règle 100230 détecte les accès de reconnaissance. Cortex et MISP peuvent enrichir un produit ou une CVE, mais la confirmation repose sur l'inventaire Wazuh et la documentation du fournisseur. La protection exige gestion des dépendances, correctifs et suppression des fichiers d'installation.

4.6.8 A07 – Identification and Authentication Failures

La règle de base 100240, niveau 5, relève chaque tentative sur le module Brute Force. La règle corrélée 100241, niveau 10, utilise `if_matched_sid`, une fréquence de cinq et une fenêtre de soixante secondes. Les protections sont le rate limiting, le verrouillage progressif, le MFA et la surveillance des identifiants compromis.

4.6.9 A08 – Software and Data Integrity Failures

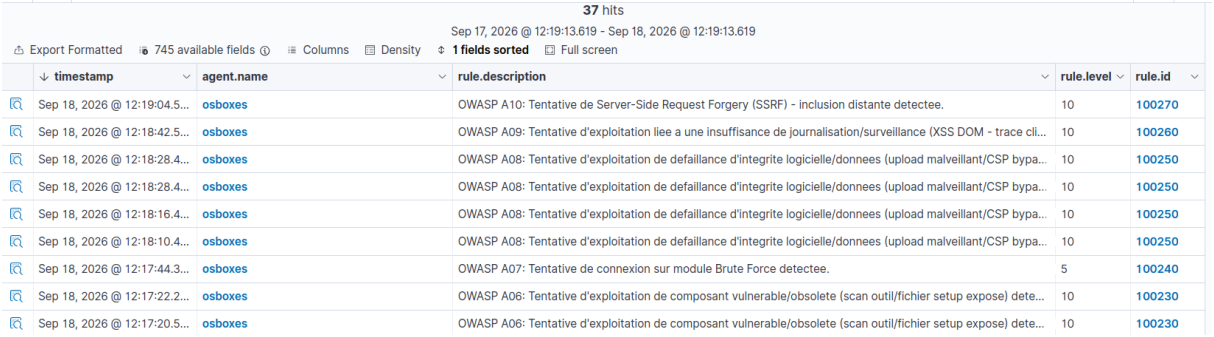
Le scénario utilise le module CSP Bypass comme support pédagogique et la règle 100250. Cette association est indirecte : A08 concerne surtout la confiance dans le code, les mises à jour et les chaînes CI/CD. Les mesures sont les signatures, les sommes de contrôle, la provenance des dépendances et un pipeline protégé.

4.6.10 A09 – Security Logging and Monitoring Failures

Le XSS DOM met en évidence un angle mort : le fragment malveillant peut être interprété uniquement dans le navigateur et ne pas apparaître entièrement dans le journal serveur. La règle 100260 détecte les traces visibles, mais le résultat illustre surtout la nécessité de journaux applicatifs, d'une télémétrie client et de tests de couverture. Une absence d'alerte n'implique donc pas une absence d'attaque.

4.6.11 A10 – Server-Side Request Forgery

Une valeur `page=http://...` force le serveur à initier une requête. La règle 100270 recherche les URL externes dans le module File Inclusion. Lorsqu'elle est transférée, TheHive peut conserver la destination ; Cortex réalise ensuite les analyses d'observables documentées dans ce chapitre. La preuve MISP fournie concerne la publication de l'événement. Les contrôles sont la liste blanche des destinations, la désactivation des inclusions distantes et la segmentation des flux sortants.



37 hits

Sep 17, 2026 @ 12:19:13.619 - Sep 18, 2026 @ 12:19:13.619

Export Formatted | 745 available fields | Columns | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 18, 2026 @ 12:19:04.5...	osboxes	OWASP A10: Tentative de Server-Side Request Forgery (SSRF) - inclusion distante detectee.	10	100270
Sep 18, 2026 @ 12:18:42.5...	osboxes	OWASP A09: Tentative d'exploitation liee a une insuffisance de journalisation/surveillance (XSS DOM - trace cli...	10	100260
Sep 18, 2026 @ 12:18:28.4...	osboxes	OWASP A08: Tentative d'exploitation de defaillance d'integrite logicielle/donnees (upload malveillant/CSP bypa...	10	100250
Sep 18, 2026 @ 12:18:28.4...	osboxes	OWASP A08: Tentative d'exploitation de defaillance d'integrite logicielle/donnees (upload malveillant/CSP bypa...	10	100250
Sep 18, 2026 @ 12:18:16.4...	osboxes	OWASP A08: Tentative d'exploitation de defaillance d'integrite logicielle/donnees (upload malveillant/CSP bypa...	10	100250
Sep 18, 2026 @ 12:18:10.4...	osboxes	OWASP A08: Tentative d'exploitation de defaillance d'integrite logicielle/donnees (upload malveillant/CSP bypa...	10	100250
Sep 18, 2026 @ 12:17:44.3...	osboxes	OWASP A07: Tentative de connexion sur module Brute Force detectee.	5	100240
Sep 18, 2026 @ 12:17:22.2...	osboxes	OWASP A06: Tentative d'exploitation de composant vulnerable/obsolete (scan outil/fichier setup expose) dete...	10	100230
Sep 18, 2026 @ 12:17:20.5...	osboxes	OWASP A06: Tentative d'exploitation de composant vulnerable/obsolete (scan outil/fichier setup expose) dete...	10	100230

Figure 4.9 : Détection des attaques OWASP A06 à A10 dans Wazuh

Code	**Module / test**	**Règle**	**Résultat attendu et contrôle**
A01	File Inclusion	100190	Traversée détectée ; liste blanche.
A02	Weak Session IDs	100200	Accès suspect ; sessions aléatoires et TLS.
A03	SQLi / XSS	100180, 100181	Motifs détectés ; requêtes paramétrées et encodage.
A04	CSRF	100210	Action sensible détectée ; jeton CSRF.
A05	phpinfo exposé	100220	Diagnostic exposé ; durcissement.
A06	setup / versions	100230	Reconnaissance détectée ; correctifs.
A07	Brute force	100240, 100241	Corrélation après cinq essais ; MFA et limitation.
A08	CSP Bypass	100250	Test pédagogique ; intégrité de la chaîne logicielle.

Code	Module / test	Règle	Résultat attendu et contrôle
A09	XSS DOM	100260	Couverture partielle ; télémétrie applicative.
A10	URL externe	100270	SSRF détectée ; filtrage des sorties.

Tableau 4.2 : Synthèse des règles Wazuh pour l'OWASP Top 10

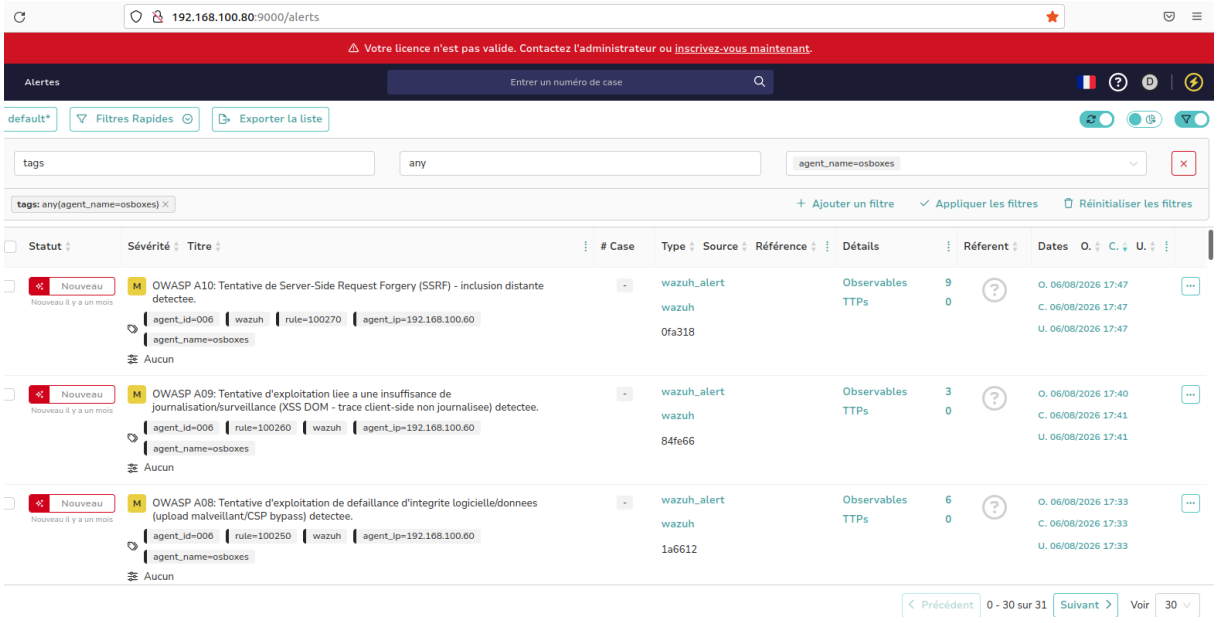


Figure 4.10 : Alertes Wazuh visibles dans TheHive

Limitation observée. La capture TheHive affiche un message indiquant que la licence n'est pas valide. La création et le traitement d'un cas ne sont donc pas retenus comme résultat démontré dans cette version du laboratoire.

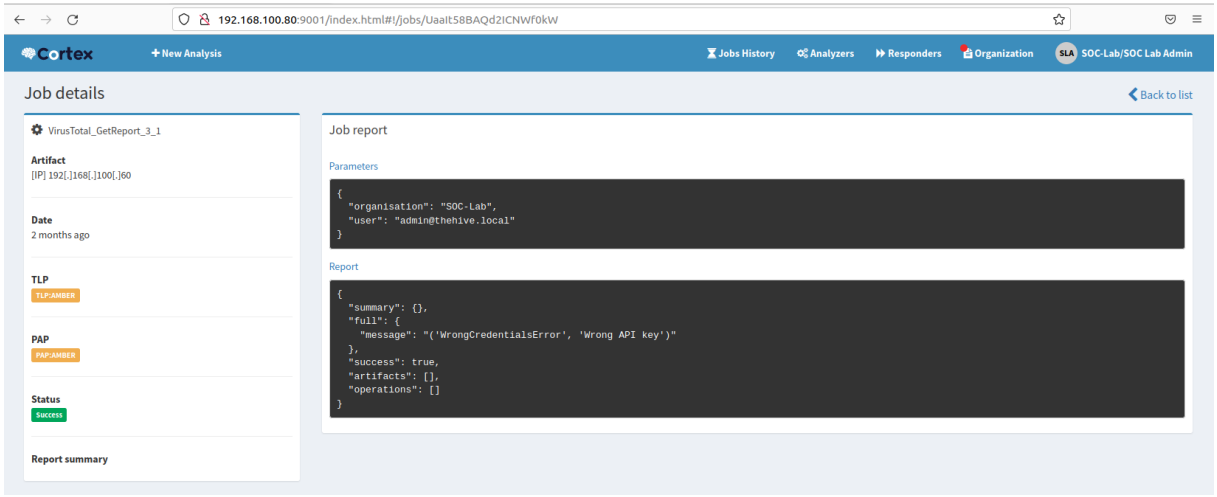


Figure 4.11 : Analyse d'un observable avec Cortex et VirusTotal

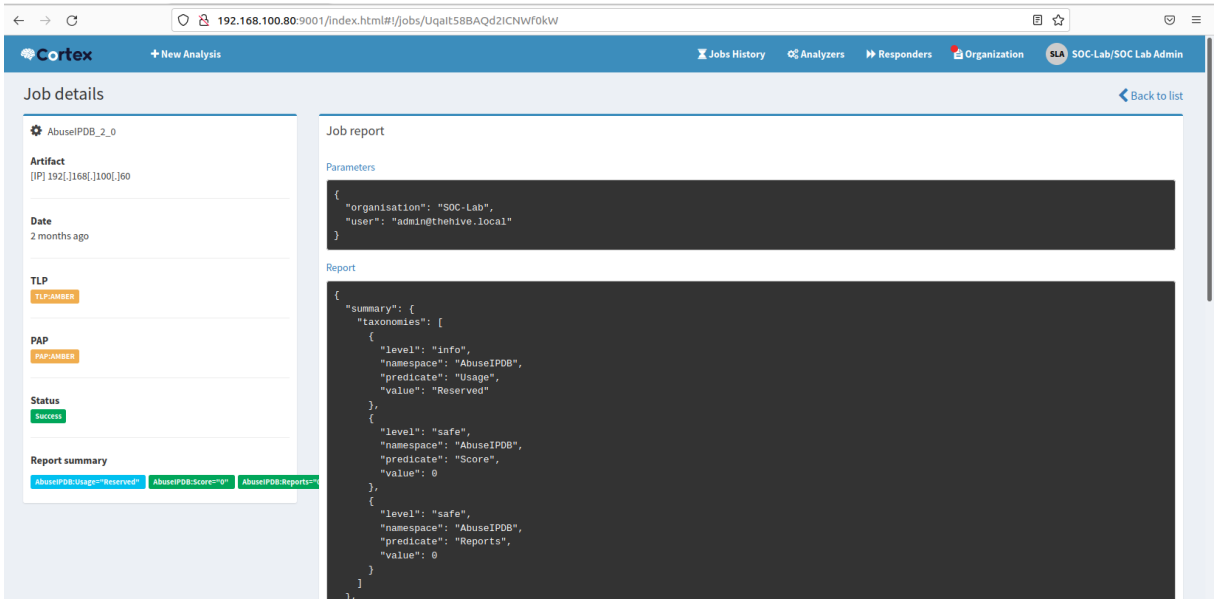


Figure 4.12 : Analyse de réputation d'une adresse IP avec AbuseIPDB

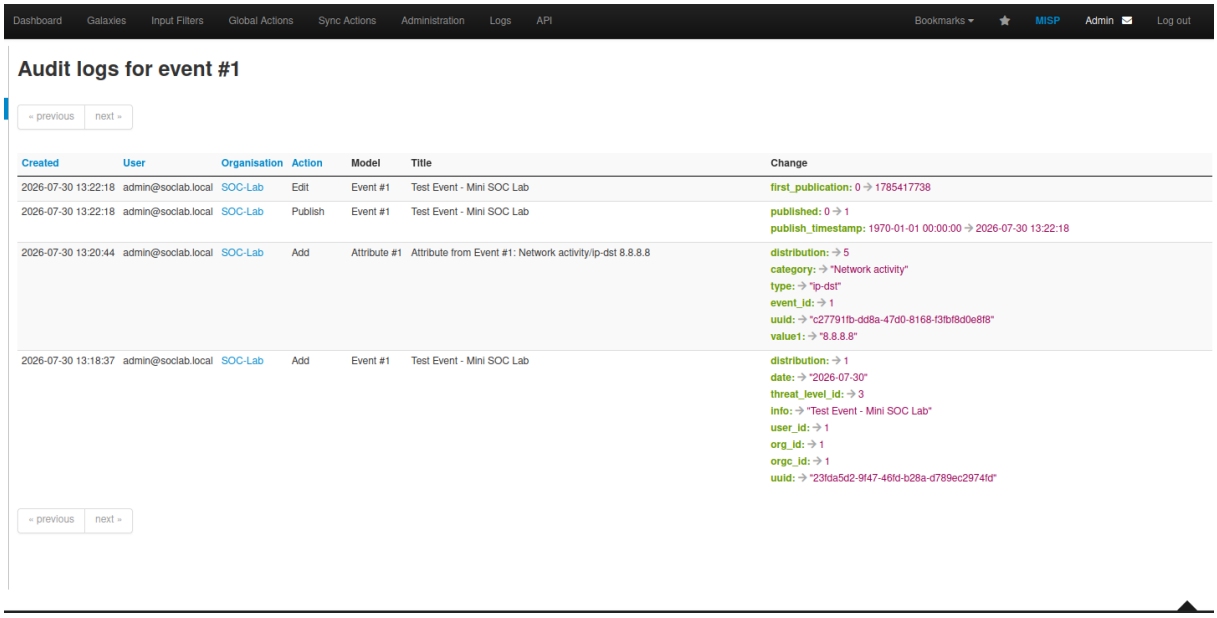


Figure 4.13 : Traçabilité de la publication de l'événement MISP

4.7 Active Response

La configuration fournie active `firewall-drop` pour les règles critiques OWASP. La capture de configuration montre notamment les règles 100190, 100200, 100210, 100220, 100230, 100240, 100241, 100250, 100260 et 100270. Le délai configuré dans la capture doit être vérifié avec la valeur effectivement appliquée au moment du test.

```
<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
```

```
  <timeout_allowed>yes</timeout_allowed>
</command>
<active-response>
  <disabled>no</disabled>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100190,100200,100210,100220,100230,100241,100250,100260,100270</rules_id>
  <timeout>600</timeout>
</active-response>
```

Le choix `local` applique l'action sur le Manager dans la démonstration. En production, le point de blocage doit être choisi selon le chemin réel du trafic ; un blocage sur le Manager ne protège pas nécessairement DVWA. Une intégration avec pfSense serait plus cohérente pour un confinement centralisé.

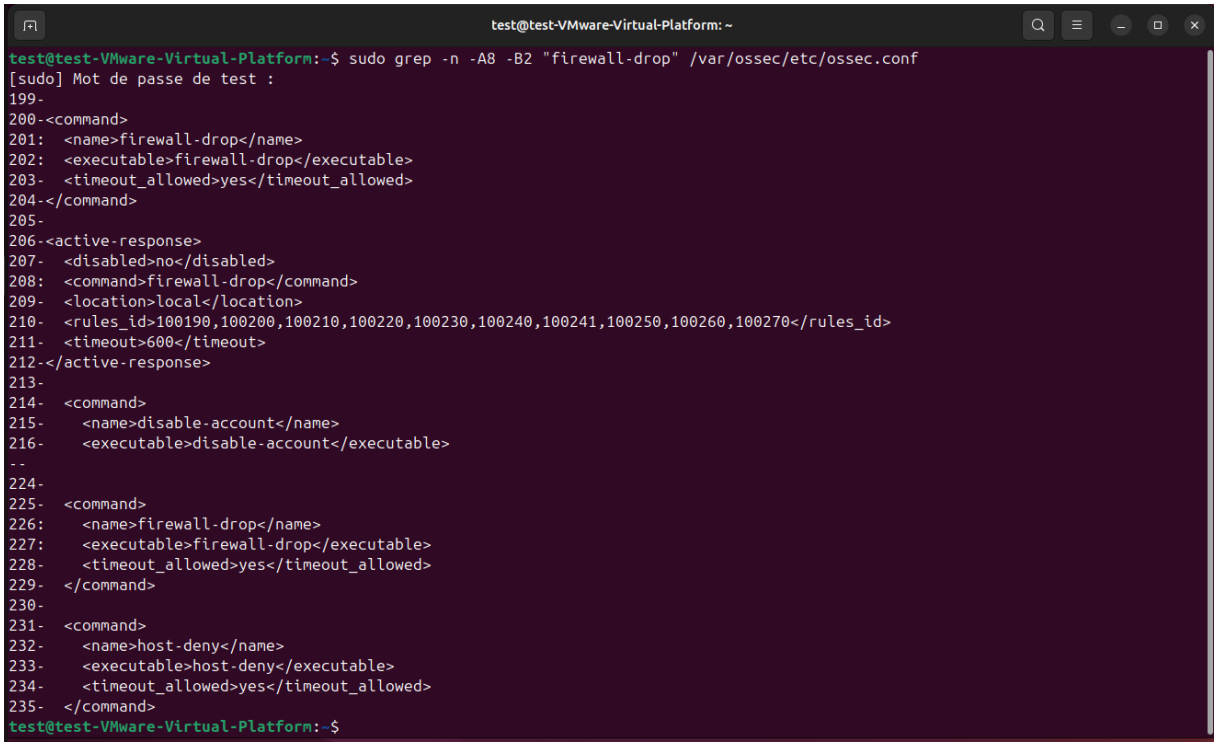


Figure 4.14 : Configuration de la réponse active firewall-drop dans Wazuh

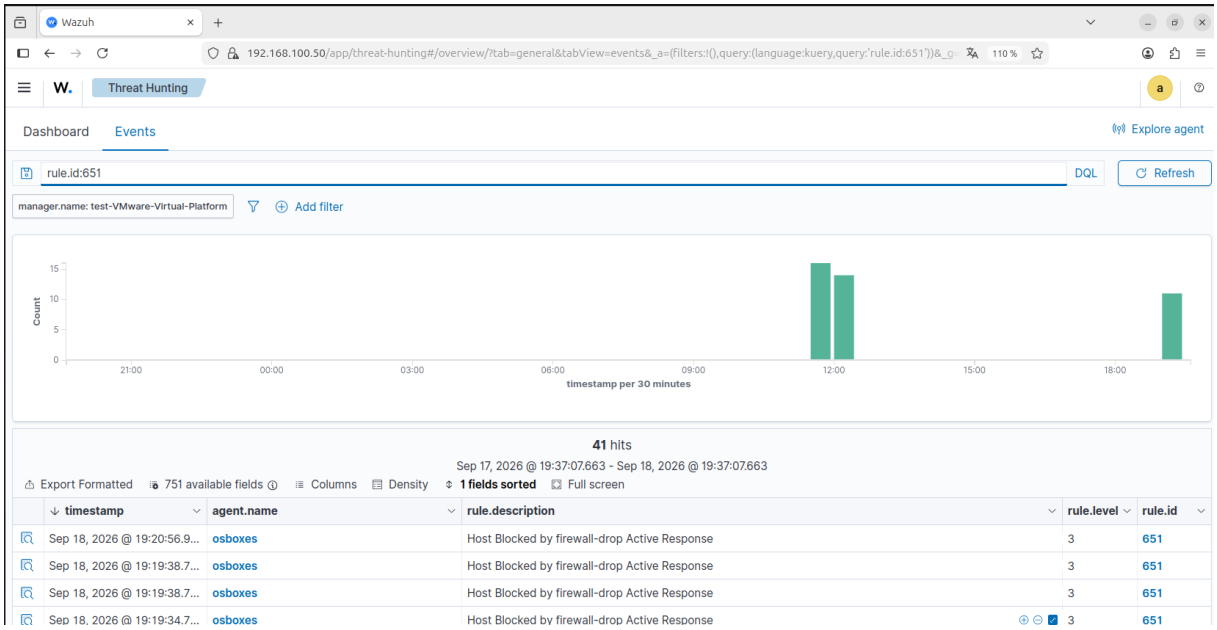


Figure 4.15 : Exécution de la réponse active – règle 651 « Host Blocked by firewall-drop »

4.8 Tableau MITRE ATT&CK

Scénario	**Technique**	**Source**	**Règles / module**
Force brute SSH	T1110	Journaux SSH/PAM	5760, 5503
Force brute RDP	T1110	Windows Security	60122
Altération de fichiers	T1565	FIM/syscheck	550, 554
Scan réseau	T1595	Nmap et inventaire	Vulnerability Detection
Scan pfSense	T1595.001	filterlog/syslog	100160, 100161
Exploitation web	T1190	Apache/DVWA	100180–100270

Tableau 4.3 : Cartographie des scénarios avec MITRE ATT&CK

4.9 Discussion des résultats

La chaîne multi-source est opérationnelle : Linux, Windows, pfSense et Apache alimentent Wazuh ; des alertes Wazuh sont visibles dans TheHive ; Cortex exécute les analyses d'observables. La capture MISP fournie prouve la publication et la traçabilité de l'événement, mais ne constitue pas à elle seule une preuve de synchronisation MISP → TheHive. Le filtrage par niveau et par fichier réduit le bruit. Les limites principales sont la dépendance à la qualité des journaux, le caractère expérimental de certaines correspondances OWASP, l'absence de mesure systématique des faux positifs et l'absence

de preuve graphique dédiée pour certaines étapes, notamment la création d'un cas TheHive et la synchronisation MISP → TheHive.

Conclusion

Les scénarios valident les fonctions essentielles d'un mini-SOC : visibilité, corrélation, transfert d'alertes, enrichissement et réponse active limitée. La gestion complète d'un cas TheHive n'est pas retenue comme preuve dans cette version en raison de la licence affichée dans l'interface. La validation est plus robuste lorsque chaque alerte est reliée à une preuve de journal et à une règle précise. Les annexes fournissent les éléments de configuration nécessaires à la reproduction.

Conclusion générale

Ce projet a abouti à la conception et à l'intégration d'un laboratoire SOC open source couvrant plusieurs couches du système d'information. pfSense assure le routage, le filtrage et la production de journaux réseau ; Wazuh centralise et corrèle les événements Linux, Windows et web ; TheHive structure les alertes et les incidents ; Cortex enrichit les observables ; MISP apporte un contexte de menace. Kali Linux, Ubuntu/DVWA et Windows Server 2019 fournissent un environnement d'expérimentation contrôlé et reproductible.

Les essais ont validé la détection de la force brute SSH et RDP, des changements de fichiers, de la reconnaissance réseau et des blocages pfSense. La couche applicative a été progressivement étendue aux dix catégories OWASP Top 10 au moyen de règles personnalisées 100180 à 100270. Le filtrage de niveau 10 et la règle FIM 100170 démontrent qu'une intégration utile ne consiste pas à transférer tous les événements, mais à sélectionner ceux qui nécessitent une investigation. Le test MISP → TheHive → Cortex et l'intégration Wazuh → TheHive valident la chaîne de gestion et d'enrichissement.

La principale contribution du travail réside dans l'approche de bout en bout : chaque scénario relie une action contrôlée à un journal, un décodeur, une règle, une alerte et une décision. Les difficultés de réseau, de versions d'agent, de décodeurs et de stabilité du conteneur ont également produit une méthode de diagnostic réutilisable. La chronologie des pièces sources montre enfin que la validation OWASP et l'Active Response ont été finalisées après le premier rapport consolidé du 6 août 2026 ; cette distinction préserve l'intégrité des résultats.

Le laboratoire présente néanmoins des limites. Il ne mesure pas encore systématiquement le taux de faux positifs, le temps moyen de détection ou le temps moyen de réponse. Certaines règles OWASP reconnaissent des motifs d'URL et peuvent être contournées par encodage ou produire des alertes sur des requêtes légitimes. Le SIEM n'est ni un WAF ni un IDS réseau : une attaque côté client peut ne laisser aucune trace exploitable dans Apache. La colocalisation de TheHive, Cortex et éventuellement MISP crée aussi un point de défaillance commun. Enfin, les pièces transmises ne contiennent pas les exportations graphiques des tableaux de bord ; celles-ci devront être ajoutées avant le dépôt si elles sont disponibles.

Les perspectives prioritaires sont l'intégration de Suricata à pfSense, l'utilisation de TLS entre les composants, la centralisation des secrets dans un coffre, la synchronisation NTP vérifiée, la sauvegarde des index, l'ajout de tests de régression pour les règles et l'automatisation de playbooks avec validation humaine. Une étude quantitative pourrait mesurer la précision, la latence de détection et la charge de l'analyste.

Bibliographie

[1] National Institute of Standards and Technology, « The NIST Cybersecurity Framework (CSF) 2.0, » NIST, rapp. tech. NIST CSWP 29, 2024. doi : 10.6028/NIST.CSWP.29

[2] P. Cichonski, T. Millar, T. Grance et K. Scarfone, « Computer Security Incident Handling Guide, » National Institute of Standards et Technology, rapp. tech. NIST SP 800-61 Rev. 2, 2012. doi : 10.6028/NIST.SP.800-61r2

[3] Société Tunisienne de Banque, « Rapport annuel 2025, » Société Tunisienne de Banque, 2026. visité le 16 août 2026. adresse : https://www.stb.com.tn/wp-content/uploads/2026/05/RAPPORT-ANNUEL-STB-2025.pdf

[4] OWASP Foundation. « OWASP Top 10 :2021, » visité le 16 août 2026. adresse : https://owasp.org/Top10/

[5] MITRE Corporation. « MITRE ATT&CK Enterprise Matrix, » visité le 16 août 2026. adresse : https://attack.mitre.org/

[6] International Organization for Standardization, *ISO/IEC 27001 :2022 Information security management systems – Requirements*, ISO, 2022.

[7] R. Gerhards, « The Syslog Protocol, » Internet Engineering Task Force, rapp. tech. RFC 5424, 2009. doi : 10.17487/RFC5424

[8] Wazuh, Inc. « Wazuh Documentation, » visité le 16 août 2026. adresse : https://documentation.wazuh.com/

[9] StrangeBee. « TheHive Documentation, » visité le 16 août 2026. adresse : https://docs.strangebee.com/thehive/

[10] StrangeBee. « Cortex Documentation, » visité le 16 août 2026. adresse : https://docs.strangebee.com/cortex/

[11] C. Wagner, A. Dulaunoy, G. Wagener et A. Iklody, « MISP : The Design and Implementation of a Collaborative Threat Intelligence Sharing Platform, » *Proceedings of the 2016 ACM on Workshop on Information Sharing and Collaborative Security*, p. 49-56, 2016. doi : 10.1145/2994539.2994542

[12] MISP Project. « MISP Project Documentation, » visité le 16 août 2026. adresse : https://www.misp-project.org/documentation/

Annexes

Annexe A – Décodeur et règles pfSense

```
<decoder name="pf-custom">
  <prematch>filterlog</prematch>
</decoder>

<rule id="100160" level="5">
  <decoded_as>pf-custom</decoded_as>
  <description>pfSense: Firewall filterlog event.</description>
</rule>
<rule id="100161" level="7">
  <if_sid>100160</if_sid>
  <match>,block,</match>
  <description>pfSense: Blocked connection.</description>
</rule>
<rule id="100162" level="10" frequency="10" timeframe="30">
  <if_matched_sid>100161</if_matched_sid>
  <description>pfSense: Multiples blocages rapides - scan probable.</description>
  <mitre><id>T1595.001</id></mitre>
</rule>
```

Annexe B – Règle FIM sélective

```
<rule id="100170" level="12">
  <if_sid>550</if_sid>
  <field name="file">fichier_critique.txt</field>
  <description>FIM: Modification du fichier CRITIQUE - escalade TheHive.</description>
</rule>
```

Annexe C – Extrait des règles OWASP

```
<group name="web,attack,owasp,">
  <rule id="100180" level="10">
    <if_sid>31100</if_sid>
    <url>UNION|SELECT|OR 1=1|--|xp_cmdshell</url>
    <description>OWASP A03: Tentative d'injection SQL detectee.</description>
    <mitre><id>T1190</id></mitre>
```

```
  </rule>
  <rule id="100181" level="10">
    <if_sid>31100</if_sid>
    <url>&amp;lt;script&amp;gt;|javascript:|onerror=|onload=</url>
    <description>OWASP A03: Tentative XSS detectee.</description>
    <mitre><id>T1190</id></mitre>
  </rule>
</group>
```

Les identifiants complémentaires issus du rapport sont : 100190 (A01), 100200 (A02), 100210 (A04), 100220 (A05), 100230 (A06), 100240/100241 (A07), 100250 (A08), 100260 (A09) et 100270 (A10). Les expressions exactes doivent être exportées depuis le fichier `local_rules.xml` de la VM avant archivage définitif ; les pièces fournies ne contiennent pas toutes les expressions complètes.

Annexe D – Commandes de validation

```
# Connectivite et ports
ping -c 4 192.168.100.50
nc -zv 192.168.100.50 1514
curl -I http://192.168.100.80:9000

# Services et journaux
sudo systemctl status wazuh-manager
sudo systemctl status wazuh-agent
sudo tail -f /var/ossec/logs/alerts/alerts.json
sudo tail -f /var/ossec/logs/integrations.log
sudo tail -f /var/log/dvwa/access.log

# Validation des regles
sudo /var/ossec/bin/wazuh-logtest
sudo systemctl restart wazuh-manager
```

Annexe E – Précautions de sécurité

Après les démonstrations, toutes les clés API susceptibles d'avoir été affichées doivent être révoquées et recréées. Les mots de passe doivent être stockés dans un gestionnaire de secrets. DVWA doit rester sur le réseau isolé. Les instantanés contenant des secrets ou des données de test doivent être protégés et supprimés lorsqu'ils ne sont plus nécessaires.

Résumé

Ce projet présente un laboratoire SOC open source déployé sous VMware Workstation sur le réseau privé `192.168.100.0/24`. L'architecture associe pfSense pour le filtrage, Wazuh pour la collecte et la corrélation, TheHive pour la gestion des incidents, Cortex pour l'enrichissement et MISP pour le renseignement. Kali Linux génère des scénarios contrôlés contre Ubuntu/DVWA et Windows Server 2019. Les essais couvrent les forces brutes SSH et RDP, la surveillance d'intégrité, la reconnaissance réseau, les vulnérabilités système et l'OWASP Top 10. Des règles Wazuh personnalisées, un filtrage par criticité et une réponse *firewall-drop* complètent la chaîne. Les résultats établissent la traçabilité du journal source jusqu'à l'alerte TheHive et son enrichissement, tout en montrant les limites d'une détection exclusivement fondée sur les journaux.

Mots clés : SOC, SIEM, SOAR, Wazuh, pfSense, TheHive, Cortex, MISP, OWASP Top 10, réponse aux incidents

Abstract

This project presents an open-source SOC laboratory deployed with VMware Workstation on the private `192.168.100.0/24` network. The architecture combines pfSense for filtering, Wazuh for event collection and correlation, TheHive for incident management, Cortex for enrichment, and MISP for threat intelligence. Kali Linux runs controlled scenarios against Ubuntu/DVWA and Windows Server 2019. Tests cover SSH and RDP brute force, file integrity monitoring, network reconnaissance, system vulnerabilities, and the OWASP Top 10. Custom Wazuh rules, severity filtering, and a *firewall-drop* response complete the chain. Results provide traceability from source logs to TheHive alerts and enrichment while highlighting the limitations of detection based exclusively on logs.

Keywords : SOC, SIEM, SOAR, Wazuh, pfSense, TheHive, Cortex, MISP, OWASP Top 10, incident response